PlayStake Master Compliance Manual

Operator	[COMPANY NAME] (company no. [REG NO]), trading as PlayStake
Registered office	[REGISTERED ADDRESS]
Website	playstake.org
Licence applied for	Remote operating licence — betting intermediary (peer-to-peer wagering on skill-based games). *To be confirmed with legal advisers before submission.*
Document owner	[COMPLIANCE LEAD NAME], Head of Compliance and Money Laundering Reporting Officer (MLRO)
Approved by	[COMPLIANCE LEAD NAME], for and on behalf of the board
Version	0.1 — draft for licence application
Effective date	[DATE OF APPROVAL]
Next review	12 months from approval, or sooner on a material change (see section 7)

> **Draft status.** This manual and the policies it indexes were prepared from the PlayStake platform as built on 30 September 2026. They describe controls that exist in the software today, and they flag clearly where something still depends on a contract, a person or a decision. Before submission, they must be reviewed by a qualified gambling-compliance adviser or solicitor. They must also be checked against the Gambling Commission's Licence Conditions and Codes of Practice (LCCP) and guidance current at that time, as requirements are updated frequently. Paragraph references to the LCCP are given for orientation and must be confirmed.

---

1. Purpose and scope

This manual is the top-level description of how PlayStake meets the licensing objectives in section 1 of the Gambling Act 2005:

1. preventing gambling from being a source of crime or disorder, being associated with crime or disorder, or being used to support crime;
2. ensuring gambling is conducted in a fair and open way;
3. protecting children and other vulnerable persons from being harmed or exploited by gambling.

It applies to every person who works for or on behalf of PlayStake, including directors, employees, contractors and outsourced providers. It also covers every part of the PlayStake service: the website at playstake.org, the lobby and challenge system, streamed matches refereed through Kick, the game guide pages at /games, payments and withdrawals, and all back-office tooling.

2. The business in brief

PlayStake is a peer-to-peer platform where adult customers wager against each other on the outcome of skill-based games they play themselves:

- **Opponents are other customers.** PlayStake never takes the other side of a bet. It holds both stakes in escrow and pays the winner. It earns a platform fee (a percentage of the pot) on settled matches.
- **Matches.** Every match is a refereed stream match in one of two third-party games: EA SPORTS FC 27 or Tekken 8. Both players broadcast their own screen on Kick. An independent, approved human referee watches both streams and records the result (a win for either player, or a draw), and every referee action is written to a tamper-evident, hash-chained audit trail. Stakes are £1 to £500.

    - PlayStake's own on-site games (Tic-Tac-Toe and Darts 301 at /play) were withdrawn on 25 October 2026. PlayStake no longer runs any game itself, and uses no random number generator to decide any outcome.
- **Money.** All money moves through a double-entry ledger with a per-match escrow account. The ledger is audited automatically every night.
- **Disputes.** Either player can dispute a result before it pays out. Payout pauses while the dispute is reviewed.

This business model shapes the risk profile, which is covered in detail in the AML Risk Assessment (Policy 07):

- **Main crime risk.** Two customers could pass money between themselves by one deliberately losing ("chip dumping").
- **Main integrity risk.** A result could be manipulated.
- **Main harm risks.** Loss-chasing and spending beyond one's means are amplified by play that is fast and competitive.

3. Governance and key people

PlayStake is a small operator at launch. One person currently holds all the key compliance roles:

Role	Holder	Responsibilities
Head of Compliance	[COMPLIANCE LEAD NAME]	Owns this manual and all policies. Monitors regulatory change. Reports to the board. Is the point of contact for the Gambling Commission.
Money Laundering Reporting Officer (MLRO)	[COMPLIANCE LEAD NAME]	Owns the AML risk assessment. Decides AML cases. Makes Suspicious Activity Reports (SARs) and Defence Against Money Laundering (DAML) requests to the NCA.
Customer Interaction / Safer Gambling Lead	[COMPLIANCE LEAD NAME]	Owns harm-signal review, customer interactions and the effectiveness evaluation.
Complaints Manager	[COMPLIANCE LEAD NAME]	Owns the complaints procedure. Issues final responses. Is the liaison with IBAS.
Personal Management Licence holders	[NAMES]	As required by the Commission for the specified management offices.

Segregation of duties. The Commission expects key functions, especially the MLRO, to be sufficiently senior, independent and resourced. While one person holds every role, PlayStake uses four compensating controls:

1. **Audit trail.** Every privileged action is written to an append-only admin audit log that the database itself protects from edits or deletion.
2. **Independent review.** An external compliance adviser, [ADVISER NAME / FIRM], reviews a sample of AML cases, harm-signal decisions and complaints every quarter.
3. **Built-in safeguards.** The software enforces the most important rules itself, so they don't depend on one person's judgement. For example:
    - age cannot be marked verified without an approved adult identity document
    - staff cannot change their own role
    - self-exclusion cannot be lifted early by anyone
    - staff can only ever lower a customer's deposit limit
4. **Separation as we grow.** Separate role holders will be appointed as the business grows, starting with the MLRO, and before monthly customer deposits exceed [THRESHOLD].

Board oversight. The board receives a compliance report every quarter covering:

- AML case volumes and outcomes, and any SARs made (numbers only)
- harm signals raised and the outcomes of interactions
- complaints: volumes, timeliness, outcomes and IBAS referrals
- ledger audit results
- any regulatory incidents or key-event notifications

4. The policies

No.	Policy	What it covers	Main controls in the platform
01	Crime Prevention and Fraud Controls	Account security, multi-accounting, collusion and match integrity, payment fraud, staff controls	2FA (required for staff), rate limits and lockouts, identity screening, head-to-head match cap, referee audit chain, double-entry ledger with nightly audit, chargeback suspension, append-only admin audit log
02	Complaints Procedure and ADR	How complaints are received, handled and escalated to IBAS	Reference numbers, immediate acknowledgement, 8-week deadline tracking with alerts, final-response letters naming IBAS
03	Self-Exclusion	Customer-requested self-exclusion and cool-off	6-month to 5-year exclusion, no early lifting, positive action plus 24-hour cooling-off to return, open activity withdrawn, marketing stopped, exclusion follows the person
04	Multi-Operator Self-Exclusion (GAMSTOP)	Participation in the national scheme	GAMSTOP checks at identity verification, login and before any deposit or stake; fails closed
05	Customer Interaction and Harm Prevention	Identify, act and evaluate	Five automated harm markers, immediate in-app interaction, staff review queue, operator limits and cool-offs, 14-day outcome evaluation, deposit-limit prompt before first deposit, reality checks
06	Age Verification	Keeping under-18s out	Date of birth and 18+ confirmation at sign-up, document KYC before any deposit, free-to-play access or gambling, under-18 closure process
07	AML Risk Assessment and Controls	Money laundering and terrorist financing	Risk assessment, KYC, transaction monitoring (chip dumping, shared IPs, deposit-and-withdraw-without-play, EDD threshold), withdrawal holds, case management, SAR process

The application's technical documents:

No.	Document	What it covers
08	System Diagram and Outsourcing Map	Every component and supplier, with commentary: payments, identity, geolocation, marketing, customer service, fraud detection, hosting
09	End-to-End Customer and System Flow	Registration to gambling to payout, with the checks at each step and where the equipment is
10	Operational Model Map	Location, provider and operator of every system and activity, including key equipment
11	Testing Strategy	What is tested and by whom (no PlayStake-run games or RNG since 25 October 2026), in-house testing, CI, change control, annual security audit
12	RTS Compliance Statement and Change Register	How each applicable RTS is met, RTS 12 phase 1 and 2, and how RTS changes are tracked
13	Information Security Policy	ISO/IEC 27001:2022 control mapping for the RTS security requirements, residual risks and gaps
14	Incident Response and Key Event Reporting	Triage, response, customer and ICO notification, LCCP 15.2.1 key events within 5 working days
15	UAE (GCGRA) Certification Plan	Route to GCGRA licensing and GLI-19 / GLI-33 certification with GLI or BMM (planning draft, unverified)
16	Payment Services and Payment Methods	Payments only through PSR-authorised providers; approved methods fixed in code; provider register and onboarding checklist
17	DPIA: Identity Verification (Didit)	Biometric identity checks: lawful basis, necessity, risks and controls, questions for Didit (first draft)
18	DPIA: Match Recordings	Recording every refereed match for disputes: what is recorded, who can watch, retention, risks and controls (first draft)

No.	Document	What it covers
19	Protection of Customer Funds	LCCP 4.1.1 / 4.2.1: rating "not protected – no segregation", disclosure, acknowledgement, six-monthly reminder, reconciliation
20	UKGC application answers	Form-ready answers for the technical pack and customer funds, with the document to attach for each

Each policy states its owner, its review date, the LCCP provisions it addresses, and exactly how the platform carries it out.

5. Cross-cutting controls

These controls support every policy.

5.1 One eligibility check in front of all gambling

Every deposit, every stake, and every entry to the games (including free-to-play) passes through a single check in the platform. It fails closed and checks, in order:

1. the account is **active**, not suspended or closed
2. the customer's **age and identity are verified**
3. they are **not registered with GAMSTOP**
4. they have **no cool-off or self-exclusion in force**

Withdrawals are deliberately outside this check. A self-excluded or GAMSTOP-registered customer can always take their money out.

5.2 Records and retention

- **Protected records.** Identity documents, self-exclusions and breaks, harm signals, customer interactions, complaints, AML cases and the admin audit log are all kept when a user record is deleted. The database refuses the deletion.
- **Identity documents.** These are encrypted at rest with AES-256-GCM and decrypted only when a reviewer deliberately opens one.
- **Retention periods.** The retention schedule is set out in the Privacy Policy. Financial, dispute, referee, AML and complaint records are kept for at least 5 years after the customer relationship ends, which meets the record-keeping expectation for AML purposes. **Outstanding:** an automated purge for records past their retention period is not yet built (see section 8).

5.3 Staff access

- **Role-based access.** Admin tools are restricted to the ADMIN role, checked on the server for every request.
- **Two-factor authentication.** Staff must use 2FA to reach admin tools in production.
- **Audit log.** Every privileged change is recorded in the append-only admin audit log: who, what, when, from which IP address, and why. This includes:
  - role and KYC changes
  - account suspensions and closures
  - KYC decisions
  - dispute resolutions
  - complaint handling
  - harm-signal actions
  - AML decisions
- **Viewing the log.** Staff can read the log at /admin/audit-log.

5.4 Training

All staff complete training before gaining access to customer data or admin tools, and refresh it every year. It covers:

- this manual
- AML and the tipping-off offence
- safer gambling and customer interaction
- complaints handling
- data protection

Completion is recorded in [TRAINING RECORD LOCATION].

5.5 Alerts

The platform emails the compliance inbox, [COMPLIANCE EMAIL] (configured as `EMAIL_ADMIN`), when:

- an AML case is opened
- a harm signal is raised
- an interaction has no effect
- a complaint is two weeks from, or past, its 8-week deadline
- the nightly ledger audit fails
- the anomaly scan detects unusual patterns on matches

> **Important:** without `EMAIL_ADMIN` set these alerts are silently skipped. Setting it is a go-live requirement.

6. Regulatory reporting and notifications

The Head of Compliance keeps a calendar of regulatory returns and notifications, and is responsible for them:

- **Regulatory returns** to the Gambling Commission, submitted quarterly.
- **Key event notifications**, sent within the timescales in LCCP licence condition 15.2. These include:
  - a breach of the ledger's integrity
  - a significant security incident
  - a change of ADR provider
  - the appointment or departure of key people
- **Suspicious Activity Reports** to the NCA (see Policy 07). The Commission is told where the LCCP requires it.
- **Personal data breaches** reported to the ICO within 72 hours where required.

7. Review and change control

- **Scheduled review.** Every policy is reviewed at least once a year.
- **Earlier review.** A policy is also reviewed straight away after any of the following:
  - a new product, game type, payment method or technology
  - a material change in customer behaviour or risk indicators
  - a regulatory change
  - a significant incident or complaint trend
  - a finding from the quarterly independent review
- **Version control.** Changes are recorded in each document's version history and approved by the Head of Compliance and the board.
- **Code as documentation.** The platform's code is the operative description of each control. Any change to a compliance control in the code must reference the policy it implements and be reviewed by the Head of Compliance before release.

8. Outstanding items before submission

These must be done before the application is submitted, or before real-money launch as marked. Each is also noted in the relevant policy.

#	Item	Needed for	Owner
1	Complete company details, key people and PML holders throughout these documents	Application	[COMPLIANCE LEAD NAME]
2	Sign the ADR agreement with IBAS and confirm the referral terms. The site and emails state 6 months from the final response, which must be confirmed.	Application	Complaints Manager
3	Join GAMSTOP, then set `GAMSTOP_API_KEY` and `GAMSTOP_REQUIRED=true` in production. Also confirm field requirements: collecting a mobile number may improve match rates.	Launch	Head of Compliance
4	~~Appoint an electronic identity and age verification provider~~ Didit appointed and integrated (October 2026). Remaining: sign the DPA, confirm data locations, complete the DPIA (Document 17), switch from sandbox to live	Before launch	Head of Compliance
5	Appoint a sanctions and PEP screening provider. Until then, check manually against the OFSI consolidated list at KYC approval and record the check in the review notes.	Launch	MLRO
6	Payments: move Stripe from test to live mode (the switch to GBP was made on 20 October 2026), configure Stripe Radar rules and 3-D Secure, and match the payout account holder's name to the KYC legal name	Launch	Head of Compliance / engineering
7	Set `EMAIL_ADMIN` and `SENTRY_DSN` in production, and confirm alerts arrive	Launch	Engineering
8	Confirm every staff account has 2FA enabled (enforced in production)	Launch	Head of Compliance
9	Set the AML and affordability thresholds (`AML_*` , `AFFORDABILITY_REVIEW_THRESHOLD_CENTS`) to the values in the approved risk assessment, in GBP pence	Launch	MLRO
10	Build automated data-retention purges matching the Privacy Policy	Within 3 months of launch	Engineering
11	Move rate limiting from per-process memory to Redis before running more than one web instance	Before scaling	Engineering
12	~~Add a Content-Security-Policy and frame-ancestors headers~~ Done 30 September 2026. Remaining: move to nonce-based CSP (Document 13).	Launch	Engineering
13	Update the website's licensing statement ("does not currently hold a gambling licence") to show the licence number once granted	On grant	Head of Compliance
14	Staff training programme and records	Launch	Head of Compliance
15	Engage the external compliance adviser for quarterly independent review	Launch	Board
16	Confirm the current Commission thresholds and rules on: financial vulnerability and affordability checks, consumer-set financial limit prompts, and marketing consent. Adjust the platform settings to match.	Application	Head of Compliance
17	Record the Railway region and backup location; confirm backups are enabled and test a restore	Application	Engineering
18	Decide permitted jurisdictions and add IP geolocation blocking plus a residency restriction at verification (Document 08 §6)	Launch	Head of Compliance / engineering

#	Item	Needed for	Owner
19	~~Engage a Commission-approved test house for RNG and game certification~~ No longer needed: PlayStake's own games and their RNG were withdrawn on 25 October 2026, so there is no PlayStake game or RNG to certify (Document 11 §3.1). Remaining: confirm with the Commission the in-house/third-party testing split for refereed peer-to-peer matches (Higher / Lower withdrawn 30 Sep 2026 as mostly chance)	Application	Head of Compliance
20	Commission an independent penetration test; appoint the annual security auditor (first audit within 6 months of grant)	Launch / grant + 6 months	Head of Compliance
21	Close the information security gaps in Document 13 §6 (log retention, written staff security rules, supplier assurance, key rotation, `timestamptz`)	As marked there	Head of Compliance / engineering
22	Review the 12 January 2026 update to RTS 14 against Policies 03 and 04 (Document 12 §4)	Application	Head of Compliance
23	~~Build the monthly game-fairness statistical check from the game event log~~ No longer needed: it checked dart-scatter draws, and Darts was withdrawn on 25 October 2026 (Document 11 §6)	—	Engineering
24	Get Stripe's written approval for gambling (or appoint a gambling-approved PSP) and confirm its FCA reference number (Policy 16)	Launch	Head of Compliance
25	Block credit-funded cards on deposits (Policy 16 §7)	Launch	Head of Compliance / engineering

9. Version history

Version	Date	Author	Change
0.1	30 September 2026	[COMPLIANCE LEAD NAME]	First draft for licence application

Policy 01 — Crime Prevention and Fraud Controls

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually, and on any new product, payment method or significant incident
Relates to	Licensing objective 1 (keeping crime out of gambling) and objective 2 (fair and open gambling); LCCP licence condition 12 (anti-money laundering, see Policy 07) and conditions on cheating and security; Gambling Act 2005 s.42 (cheating)

> Draft for review by a compliance adviser. LCCP references to be confirmed against the current version.

1. Purpose

This policy sets out how PlayStake stops its service being used to commit crime. It covers fraud against customers or against PlayStake, cheating and match-fixing, and misuse of accounts and payments. It also sets out what we do when crime is suspected. Money laundering and terrorist financing are covered in more depth in Policy 07.

2. Our main crime and fraud risks

Risk	Why it matters for PlayStake
Collusion and match-fixing	Customers play each other. Two accounts controlled by the same person or group can fix results, either to launder money (see Policy 07) or to defraud a third party.
Result manipulation	Results decide who gets paid. A forged or tampered result would move money unfairly.
Account takeover	A stolen account could be used to stake or withdraw another person's money.
Multi-accounting	One person running several accounts to collude, evade a self-exclusion or ban, or get round limits.
Payment fraud	Stolen cards used to deposit; chargebacks after playing or withdrawing ("friendly fraud").
Insider misuse	Staff with admin access changing records, approving identities improperly, or moving money.
Ledger error or tampering	Money created or destroyed through a software fault or deliberate change.

3. Controls

3.1 Account security

- **Passwords:**
  - at least 8 characters, with an uppercase letter, a number and a special character
  - hashed with bcrypt (cost 12); never stored or logged in plain text
- **Sign-in protection:**
  - 10 failed attempts in 15 minutes from one address triggers a 30-minute lockout
  - sign-in requests are rate-limited
  - password resets are rate-limited
- **Sessions:**
  - random 256-bit tokens, stored only as hashes

    - cookies are HttpOnly, Secure and SameSite=Lax
    - sessions expire after 7 days, or after 30 minutes without use
    - every session is revoked on a password change or reset
    - closed accounts are signed out everywhere and cannot sign in again
- **Two-factor authentication (TOTP):**
    - available to every customer
    - backup codes are stored hashed
    - codes cannot be replayed
    - setting up 2FA is rate-limited
- **Email verification** is required before identity verification or any withdrawal.
- **Cross-site request forgery:** browser requests that change data are refused if they come from another site.
- **Security headers:** HSTS, X-Content-Type-Options, Referrer-Policy and Permissions-Policy. *Outstanding: Content-Security-Policy and frame-ancestors (Master Manual §8).*

3.2 One person, one account

Customers may hold only one account (Terms of Service). This is enforced as follows:

- **At identity verification:**
    - the platform compares each new submission with every other account
    - a match on the same legal name and date of birth, or an identical identity document image, opens a `SHARED_IDENTITY` case
    - approval of the new account is blocked until the case is resolved
- **Excluded or closed customers:**
    - if the matching account is self-excluded, the exclusion is applied to the new account immediately
    - staff reviewing the case will see if the other account was closed (for example, as under-18 or for fraud)
- **Shared IP addresses:** the AML scan reviews IP addresses used in the last 30 days:
    - accounts that have played each other from the same IP address open a high-severity `SHARED_IP` case
    - four or more accounts on one address open a low-severity case for review
- **Date of birth check:** the date of birth declared at sign-up is checked against the identity document. A mismatch opens a `DOB_MISMATCH` case and blocks approval.

3.3 Match integrity and cheating

Cheating is an offence under s.42 of the Gambling Act 2005. PlayStake prevents and detects it as follows:

- **No self-play.**
    - the database refuses any bet where both players are the same account
    - the lobby and challenge flows refuse it before that point
- **Head-to-head cap.** The same two customers can play each other at most **5 times in any hour**. Repeated head-to-heads are how value is passed between colluding accounts.
- **No PlayStake-run games.** PlayStake's own on-site games (Tic-Tac-Toe and Darts 301) were withdrawn on 25 October 2026. Every match is now a refereed stream match in EA SPORTS FC 27 or Tekken 8. Past game records for the withdrawn games are kept, append-only; no new ones are created.
- **Match Rules and Referee Code of Conduct** (published at `/match-rules`):
    - players must accept the Match Rules before sending or accepting their first stream challenge
    - referees must accept the Referee Code of Conduct when they apply, and before going available or claiming a match

    - the accepted version and time are recorded for each person, so a disputed match is judged against the rules that applied; changing a rule in substance bumps the version and everyone must accept again
    - the rules cover cheating, fixing, bots, staying live, conduct, disconnects, disputes and sanctions; the Code covers independence and conflicts, no betting or gifts, officiating live, deciding only on what the streams show, written notes and confidentiality

- **Results** for every match are decided by an independent human referee:
    - referees apply, are verified (identity and age), and are approved by staff for specific games
    - a referee cannot officiate a match they are playing in, and can hold only one match at a time
    - a referee is never offered, and cannot claim, a match where they follow or are followed by either player, or where either side has blocked the other. The Referee Code of Conduct treats a follow as knowing each other. While a referee is on a match, they and its players cannot start following each other. Each claim records in the audit trail that this check found no link
    - the match can only start while both players are live on Kick with the same game declared, so the referee can watch both feeds
    - every referee action is written to an append-only, hash-chained audit trail that the database protects from edits or deletion; anyone can verify the chain for a match
    - after a decision, either player has 15 minutes to dispute it before payout
    - a match that no referee takes within 10 minutes, or that isn't finished within 2 hours of starting, is cancelled and both stakes are returned in full

- **Disputes.** Any result can be disputed before it pays out (see Policy 02). A dispute is decided by someone independent of the match: an admin, or a referee an admin has approved as a dispute reviewer. The reviewer can never be a player in the match or its referee, and is kept off any dispute where they follow, are followed by or have a block with either player. A reviewer must take a dispute before deciding it, so two people can't decide the same one. The player can point to moments in the match when filing. Every claim and decision, with written reasons, is recorded in the hash-chained referee audit trail and the admin audit log. PlayStake records every refereed match itself, from match start to result: both players' and the referee's streams, with sound and the match clock, in one video whose SHA-256 fingerprint is sealed into the referee audit trail. Reviewers watch it from the dispute, with jump points at the moments the player flagged; each viewing is logged. Recordings are deleted after 30 days, or kept 12 months after a disputed match is decided (Document 18).

- **Referee quality.** Overturned referee decisions are tracked per referee. Referees with a high overturn rate are reviewed and can be suspended.

- **Anomaly detection.** A scan every 15 minutes looks for:
    - win rates above 80%
    - winning streaks of more than 10
    - average settlement under 30 seconds
    - hourly volume spikes above 3 times normal

  It alerts staff. For third-party games it can also automatically reduce the game's escrow cap or freeze the developer account that owns it. For PlayStake's own games (EA SPORTS FC 27 and Tekken 8) it only alerts staff, so two colluding players cannot take both games offline. Player-level collusion is handled by the AML scan below.

- **Chip-dumping detection** (Policy 07). The same pair playing 5 or more times in 7 days, with one side winning at least 80% and receiving at least a set amount, opens a `CHIP_DUMPING` case.

3.4 Payments

- Identity and age must be verified before any deposit or withdrawal.
- **Deposits:**
    - between £5 and £1,000 per transaction
    - at most 5 deposit attempts an hour from one address

    - also limited by the customer's own deposit limits
- **Withdrawals:**
    - rate-limited
    - blocked while the account is suspended
    - held for review when an AML case is open, when the amount is large, or when money is going straight back out with little play (Policy 07)
- **Idempotency.** Every money movement uses an idempotency key, so a retried request can never pay twice.
- **Stripe webhooks** are verified by signature and de-duplicated.
- **Chargebacks.** A card dispute on a deposit immediately suspends the account and opens a high-severity `CHARGEBACK` case.
- **Outstanding (Master Manual §8):**
    - Stripe live mode with Radar fraud rules and 3-D Secure
    - GBP currency
    - matching the payout account holder's name to the verified legal name

3.5 The ledger

- **Double-entry.** All money moves through a double-entry ledger. Exactly one function is allowed to change balances. It always writes a debit and a matching credit that sum to zero, and it refuses to take any player or escrow account below zero.
- **Escrow per match.** Each match has its own escrow account, which must net to zero when the match is settled or cancelled.
- **Nightly audit.** Every night at 03:00 UTC, an automatic audit checks:
    - every account balance against its entries
    - every transaction for balance
    - that the system as a whole conserves money

  A failure alerts the compliance inbox and the error-monitoring service at the highest severity, for same-day investigation.

3.6 Staff and insider risk

Admin access is restricted as follows:

- **Access.** Admin tools are limited to the ADMIN role, checked on every request, and require two-factor authentication in production.
- **Audit trail.** Every privileged action is recorded in the append-only admin audit log, with the member of staff, time, IP address, what changed and the reason given.
- **Reasons required.** Staff must give a reason for every account-status, role and KYC change.
- **Rules staff cannot override.** The platform enforces these regardless of role:
    - staff cannot change their own role
    - staff cannot mark an identity as verified unless an approved identity document shows the customer is 18 or over
    - staff cannot lift or shorten a self-exclusion
    - staff can only lower a customer's deposit limit, never raise it
    - staff cannot reopen an account closed as under-18
- **Pre-employment checks.** Before being given admin access, staff complete [DBS / criminal record check and reference checks — to be confirmed].
- **Leavers.** Admin access is removed on the day a person leaves.

3.7 Software supply chain

- Every change is linted, type-checked and tested in CI before release.
- A malware scan runs on every push and weekly, following a 2026 supply-chain incident.
- Errors in production are reported to an error-monitoring service (Sentry).

4. When crime is suspected

1. **Contain.**
   - Suspend the account (`/admin/users`, with a reason). This stops deposits, stakes and withdrawals while still letting the customer sign in.
   - Unsettled matches can be voided with both stakes refunded where needed.
2. **Record.** Open or use an AML case (`/admin/aml`), and record the evidence and every decision on it.
3. **Decide.** The MLRO decides whether to:
   - make a Suspicious Activity Report (Policy 07)
   - report to the police or Action Fraud
   - notify the Gambling Commission as a key event
4. **Don't tip off.** Customers are not told that a report has been considered or made.
5. **Put it right.** Refund innocent third parties. Close accounts involved in fraud or cheating, and forfeit winnings obtained by cheating where the Terms allow.
6. **Learn.** Review the controls and update this policy.

5. Review

The Head of Compliance reviews this policy every year and after any significant incident. Any change to the controls described here requires an update to this document.

Version	Date	Change
0.1	30 September 2026	First draft

Policy 02 — Complaints Procedure and Alternative Dispute Resolution

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Complaints Manager
ADR provider	IBAS — Independent Betting Adjudication Service (www.ibas-uk.com). *Agreement to be signed before submission.*
Version	0.1 — draft for licence application
Review	Annually, and on any change of ADR provider (a key event to notify to the Commission)
Relates to	LCCP social responsibility code 6.1.1 (complaints and disputes) and the ADR requirements; the Alternative Dispute Resolution for Consumer Disputes Regulations 2015

> Draft for review by a compliance adviser. IBAS referral terms (including the time limit for referral) must be confirmed with IBAS when the agreement is signed.

1. Purpose

Customers must be able to complain easily, get a fair and timely answer, and take the complaint to an independent body if they are not satisfied. This policy explains how PlayStake makes that happen, and how the platform supports it.

2. What counts as a complaint

A **complaint** is any expression of dissatisfaction with PlayStake, whether spoken or written. That includes complaints about:

- the account, deposits or withdrawals
- a bet or its result
- a referee
- responsible-play tools
- how we have treated the customer
- how we handled an earlier dispute

A **result dispute** is a narrower, faster process. A player uses the dispute button on a bet to challenge a result before it pays out:

- **Timing:** within 24 hours of the result, or within 15 minutes of a referee's decision.
- **Effect:** payout pauses while staff review the game data, stream footage and referee evidence.

A customer unhappy with a dispute outcome can then make a complaint. Anything that is not a simple result challenge is handled as a complaint from the start. If in doubt, staff treat it as a complaint.

3. How customers complain

Customers can complain in two ways:

- **Online:** through the complaint form at **playstake.org/complaints**. It works whether or not the customer is signed in, so someone locked out of their account can still use it.
- **By email:** to **support@playstake.org** (the address is shown on the complaints page, in the footer, in the Terms of Service and on every email). Staff log each email complaint into the complaints system on the day it arrives.

The /complaints page explains, in plain English:

- how to complain
- what happens next and when
- the 8-week deadline
- how to take the complaint to IBAS, and that IBAS is free and independent
- how complaints relate to result disputes
- other organisations: the Gambling Commission (which cannot resolve individual complaints), the ICO for data protection, and GamCare for support

It is linked from the site footer, from the Terms of Service (sections 09 and 17) and from every complaint email.

4. How complaints are handled

Stage	What happens	Timescale	How the platform supports it
1. Received	Complaint recorded with a unique reference (**PS-C-YYYY-NNNNNN**), a category, and any linked bet (only a bet the customer was in can be linked).	Immediately	A database sequence issues references, so two complaints can never share one.
2. Acknowledged	The customer is emailed their reference, the date by which they will get a final response, and how to reach IBAS.	Immediately	Automatic acknowledgement email.
3. Investigated	A handler reviews the complaint and relevant records, and asks the customer for more information if needed. Internal notes and messages to the customer are recorded against the complaint.	As soon as possible	Staff queue at /admin/complaints, sorted by deadline. Overdue complaints are flagged in red, and those due within 14 days in amber.
4. Final response	A written decision (upheld, partially upheld, or not upheld) with the reasons, and what will be done to put things right. The letter explains how to refer the complaint to IBAS if the customer is not satisfied.	**Within 8 weeks** of receipt	The final-response email always includes the IBAS referral wording and link. Once it is issued, the complaint is locked.

Deadline alerts. The compliance inbox receives an alert when a complaint is 2 weeks from its 8-week deadline, and again if the deadline passes without a final response.

Accountability. Every staff action on a complaint is recorded in the append-only admin audit log: the note, message, status change or final response, and who made it.

5. Handling standards

- **Be fair.** Decide on the evidence, not on who the customer is or how they complained.
- **Keep money safe.** Where a bet or balance is involved, the funds stay protected while the complaint is investigated.
- **Be plain.** Write in clear English. Explain the reasons, not just the outcome.
- **Put it right.** If we got something wrong, correct it (including any money owed) and say what we will change.
- **Watch for harm.** If a complaint suggests the customer may be experiencing gambling harm, refer it to the Safer Gambling Lead and record a customer interaction (Policy 05).
- **Watch for crime.** If a complaint reveals suspected fraud or money laundering, refer it to the MLRO. Do not tip off the customer (Policy 07).

6. Alternative Dispute Resolution — IBAS

PlayStake's ADR provider is **IBAS**, the Independent Betting Adjudication Service. It is approved by the Gambling Commission as an ADR entity for gambling disputes.

- **When customers can refer:** once they have our final response and are not satisfied, or if we have not given a final response within 8 weeks.
- **Cost:** IBAS is free for customers.
- **Time limit:** customers should refer within six months of our final response. *This is the period stated on the site and in our emails; it must be confirmed against IBAS's terms when the agreement is signed.*
- **Where we tell customers about IBAS:** on the /complaints page, in the Terms of Service, in the acknowledgement email, and in every final-response email.
- **Our commitment:** PlayStake cooperates fully with IBAS, provides the records it asks for promptly, and complies with its decisions. *Confirm the binding nature of decisions against the IBAS agreement.*
- **Changing provider:** any change of ADR provider will be notified to the Commission as a key event, and the site and emails updated first.

7. Records and reporting

- **What is kept:** each complaint, its full history, the final response and the outcome. These are kept for at least 5 years and are not deleted with the customer's account.
- **Regulatory returns:** complaint volumes, categories, outcomes, timeliness and IBAS referrals are included in the Commission's regulatory returns.
- **Board reporting:** the same figures go into the quarterly board compliance report.
- **Trend review:** the Complaints Manager reviews complaint trends each quarter and feeds lessons into product and policy changes.

8. Review

Version	Date	Change
0.1	30 September 2026	First draft

Policy 03 — Self-Exclusion

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Safer Gambling Lead
Version	0.1 — draft for licence application
Review	Annually
Relates to	LCCP social responsibility code 3.5.3 (self-exclusion, remote), and 3.5.6 (multi-operator self-exclusion — see Policy 04); marketing restrictions for self-excluded customers

> Draft for review by a compliance adviser. LCCP references to be confirmed against the current version.

1. Purpose

Self-exclusion lets a customer stop themselves gambling with PlayStake for a period they choose. The period can't be undone while it runs. This policy explains:

- how customers self-exclude
- what happens while they are excluded
- how exclusion ends
- how the platform makes sure an excluded customer cannot gamble with us or be marketed to

It also covers the shorter **cool-off** break, which works in the same way for a shorter time. Participation in the national scheme, GAMSTOP, is covered in Policy 04.

2. Periods offered

Option	Periods
Self-exclusion	6 months, 1 year, 2 years, 5 years
Cool-off (take a break)	24 hours, 72 hours, 1 week, 1 month, 6 weeks

The minimum self-exclusion is six months.

3. How customers self-exclude

- **Self-service:** from **Safer Gambling** in their account, available from every page in the account area.
  - The customer picks a period.
  - A confirmation screen explains in plain English:
    - what happens
    - that the exclusion cannot be shortened or lifted early by the customer or by our staff
    - that they can still sign in and withdraw their balance
    - that anything waiting in a lobby, and any challenges, will be withdrawn
    - that when the period ends the account stays closed to gambling until they ask to return
  - The customer must confirm before the exclusion starts.
- **By contacting us:**
  - A customer can ask by email (support@playstake.org) or any other contact.
  - Staff apply it straight away from the customer's admin page, recording how the customer asked.
  - This is audited, and the same rules apply as for self-service.

    - Staff must never try to talk a customer out of self-excluding.
- **Confirmation:** the customer gets an email confirming the exclusion and its end date, with GamCare's details.
- **Signposting:** the Safer Gambling page tells customers about GAMSTOP, so they can exclude from every UK-licensed online operator at once, and gives the contact details for GamCare (0808 8020 133) and BeGambleAware.

4. What happens during self-exclusion

From the moment a self-exclusion starts:

1. **No gambling.** Every deposit, stake and game entry passes the eligibility check (Master Manual §5.1). A self-excluded customer is refused at each of:
    - depositing
    - issuing a challenge
    - accepting a challenge
2. **Open activity is withdrawn.** The following are cancelled at once, so they cannot be drawn into a match:
    - challenges they have sent or received

    Nothing needs refunding at this point, because stakes are only taken once a match is agreed.
3. **They can't be pulled into a match by someone else.** If another player tries to accept a challenge from a customer who has since self-excluded, the platform re-checks the customer before taking their stake, and refuses. The other player is told only that the player "isn't available". The reason is never disclosed.
4. **Matches already agreed** before the exclusion run to their normal end and settle as usual. Voiding them would unfairly affect the opponent.
5. **Withdrawals stay open.** The customer can still sign in and withdraw their whole balance at any time. On request, staff close the account and return the balance.
6. **No marketing or optional emails.** While any break is in force, the customer receives only essential emails (security, payments, responsible play). They get no promotional email even if they previously consented to it (including emails when a streamer they follow goes live), no optional notifications, and no in-app go-live alerts. They are also hidden from player search and their profile can't be viewed or followed, so other players can't find them and invite them to play. The same applies to customers registered with GAMSTOP and to restricted accounts.
7. **No early end.** The exclusion cannot be shortened or lifted by the customer or by staff. The platform only allows it to be replaced by a longer one.
8. **It follows the person.** If the excluded customer opens another account, the new account's identity documents are matched to them at verification. The same exclusion is applied to the new account automatically, and a case is opened for staff to review (Policy 01 §3.2).

5. How self-exclusion ends

A self-exclusion does **not** lapse on its own:

1. When the period ends, the customer is emailed. The email explains that their account **stays closed to gambling**, that nothing changes unless they choose to come back, how to return if they want to, and where to get support.
2. To return, the customer must take a **positive action**: asking to return from Safer Gambling and confirming it.
3. Access then resumes after a **24-hour cooling-off period**. During that time the account stays closed, and the page shows when it reopens. The customer is encouraged to set deposit limits first.

A cool-off ends automatically at the end of its period, and the customer is emailed when it does.

6. Staff responsibilities

The Safer Gambling Lead is responsible for:

- applying self-exclusions requested by email or phone the same day, and recording how the request arrived
- never shortening, lifting or trying to talk a customer out of a self-exclusion (the platform prevents this anyway)
- when a shared-identity case shows a new account linked to a self-excluded person, confirming the exclusion was applied, and considering whether the customer should be contacted with support information
- making sure no marketing list or promotion ever includes excluded customers (the platform enforces this for its own emails; any external or manual marketing must be filtered against the platform's exclusion data first)
- checking a sample of self-exclusions every month, to confirm they were applied correctly and no gambling or marketing followed

7. Records

- **What is kept:** self-exclusions and breaks (start, end, return request, return effective date).
- **How long:** kept even if the customer's account is later deleted, for at least 5 years after the exclusion ends.
- **Audit trail:** staff-applied exclusions appear in the admin audit log.

8. Review

Version	Date	Change
0.1	30 September 2026	First draft

Policy 04 — Multi-Operator Self-Exclusion (GAMSTOP)

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually, and on any change to GAMSTOP's integration requirements
Relates to	LCCP social responsibility code 3.5.6 — participation in the national online multi-operator self-exclusion scheme (GAMSTOP)

> Draft for review by a compliance adviser. **Status: PlayStake has not yet joined GAMSTOP.** The integration is built and tested, and switches on with configuration once membership and API credentials are in place (section 6).

1. Purpose

GAMSTOP lets a person exclude themselves from every online gambling business licensed in Great Britain in one step. Remote operators must take part in the scheme and must not let a GAMSTOP-registered person gamble. This policy describes how PlayStake checks GAMSTOP and acts on the result.

2. When PlayStake checks GAMSTOP

The check needs the customer's identity. PlayStake uses the details from their identity-verification submission: legal first and last name, date of birth, postcode and email address.

When	What happens
Identity verification submitted	Checked as soon as identity is known, before the account is approved.
Every sign-in	Checked again on each sign-in. A GAMSTOP outage here never blocks sign-in, because the customer may need to withdraw.
Before any deposit, stake or game entry	The eligibility check (Master Manual §5.1) uses the stored result if it is under 24 hours old. Otherwise it checks GAMSTOP again first.

3. How the result is used

GAMSTOP result	What PlayStake does
Registered (excluded)	The customer cannot deposit, stake or play, and is told why in plain terms. They can still sign in and **withdraw their balance**. They receive no marketing or optional emails.
Previously registered (exclusion lapsed)	Treated as not excluded for access. The fact is visible to staff on the customer's admin page, and staff may consider it in customer-interaction decisions.
Not registered	No restriction.
Check could not be completed (timeout or error)	**Fails closed.** The deposit or stake is refused with a "try again shortly" message, and the failure is logged. If a customer has never been checked, they cannot gamble until a check succeeds.

Staff view. The latest result and the time it was checked are shown on the customer's admin page.

Launch safeguard. A production setting (`GAMSTOP_REQUIRED=true`) makes the platform refuse all gambling if the GAMSTOP integration is ever switched off or misconfigured. Gambling can never quietly continue without the check.

4. Other controls that work alongside GAMSTOP

- **Signposting.** The Safer Gambling page, and the site footer on every public page, tell customers about GAMSTOP and link to it.
- **Our own exclusion.** PlayStake's own self-exclusion (Policy 03) works independently of GAMSTOP, and applies to a person across all of their accounts.

5. Records

- **Stored on the account:** the latest GAMSTOP result and the time it was checked.
- **Logged:** failed checks.
- **Not stored:** the details sent to GAMSTOP are not kept in addition to the identity-verification record.

6. Go-live steps (outstanding)

1. Apply to join GAMSTOP and sign the operator agreement.
2. Obtain API credentials. Confirm the current API endpoint, the required fields, and how the response is returned. The integration expects GAMSTOP's operator API (form fields: first name, last name, date of birth, email, postcode, mobile; an `X-Exclusion` response header of Y, N or P). *Confirm against GAMSTOP's current specification.*
3. Decide whether to collect a **mobile number** at identity verification, since GAMSTOP accepts it and it may improve matching.
4. Set `GAMSTOP_API_KEY` and `GAMSTOP_REQUIRED=true` in production (and `GAMSTOP_API_URL` if GAMSTOP specifies a different endpoint).
5. Run GAMSTOP's test cases against the staging environment and keep the evidence.
6. Record the go-live date in this policy's version history.

7. Review

Version	Date	Change
0.1	30 September 2026	First draft; integration built, awaiting membership

Policy 05 — Customer Interaction and Harm Prevention

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Safer Gambling Lead
Version	0.1 — draft for licence application
Review	Annually; the effectiveness data (section 6) is reviewed every quarter
Relates to	LCCP social responsibility code 3.4.3 (customer interaction, remote) and the Commission's customer interaction guidance ("identify, act, evaluate"); financial vulnerability / affordability requirements; restrictions on marketing to customers at risk; the requirement to offer financial limits

> Draft for review by a compliance adviser. **The Commission's current thresholds for financial vulnerability checks and its rules on prompting customers to set limits must be confirmed, and PlayStake's thresholds set to match** (see section 3.2 and Master Manual §8 item 16).

1. Purpose

PlayStake must spot customers who may be experiencing, or be at risk of, gambling harm, act quickly and appropriately, and check whether what it did worked. This policy describes the system that does that.

Scale does not excuse us. Player-versus-player wagering on competitive games can be fast, emotional and repeated: a loss invites a rematch. PlayStake treats harm prevention as a core function, not an add-on.

2. Tools every customer has

These tools are available to every customer, from **Safer Gambling** in their account:

- **Deposit limits:**
  - daily, weekly and monthly, over rolling periods
  - lowering a limit takes effect immediately
  - raising or removing a limit only takes effect after 24 hours, so it can't be done in the heat of a session
- **A limit prompt before the first deposit.** Before their first deposit, every customer must either set a deposit limit or actively decline to. The platform enforces this, not just the page, and records the answer.
- **Cool-off breaks and self-exclusion.** See Policy 03.
- **Reality checks:**
  - optional reminders every 15, 30, 60 or 120 minutes
  - each one shows how long the customer has been playing, how many bets they have placed, how much they have staked, and their net result
  - each one offers to take them to Safer Gambling
  - they run on the dashboard and on the game pages
- **Support information** from GamCare and BeGambleAware, and GAMSTOP signposting.

3. Identify: markers of harm

A scan runs **every 15 minutes**. It covers every customer who has played or deposited in the last 24 hours and looks for these markers:

Marker	Triggered when	Severity
Loss chasing — stakes	Three or more consecutive losses in 24 hours, with the last stake at least double the first	Low at 2×, medium at 3×, high at 4×
Loss chasing — deposits	Three or more deposits in 24 hours, each within 30 minutes of a losing result	Medium; high at six or more
Rapid deposits	Five deposits in an hour, or ten in 24 hours	Medium; high at double those numbers
High deposit volume (affordability)	Completed deposits over 30 days at or above the affordability threshold (setting `AFFORDABILITY_REVIEW_THRESHOLD_CENTS`; currently 2,000.00)	Medium; high at double
Late-night play	Five or more bets settled between midnight and 6am UK time in 24 hours	Low; medium at ten or more

Signal frequency. Each marker raises a signal at most once in 24 hours per customer, or once in 30 days for high deposit volume, so a single episode doesn't flood the queue.

Other indicators staff consider during review. Some indicators are not yet automated. Staff consider them whenever they review a customer. They are:

- how the customer uses the gambling management tools, such as raising or removing limits or ending breaks
- repeated declined deposits or cancelled withdrawals
- time spent on the site
- a complaint or other contact that suggests distress
- anything else the customer tells us

Customer-led contact. Any contact from a customer that suggests harm, whether a complaint, an email or something else, must be recorded by staff as an interaction on that customer (see section 4.2).

3.1 Customers we already know about

Some customers are already handled before any scan runs. If a customer has self-excluded, is on a break, is registered with GAMSTOP, or has a restricted account, they cannot gamble at all.

3.2 Affordability and financial vulnerability

Current threshold. The high-deposit-volume marker is PlayStake's affordability trigger. It is set at 2,000.00 of deposits over 30 days.

Aligning with the Commission. Before launch, this threshold must be set at or below the level at which the Commission requires financial vulnerability checks. Our AML enhanced due diligence threshold (Policy 07, 5,000.00 over 30 days) requires source-of-funds evidence. Customers who cannot show that their spending is affordable are restricted.

Planned improvement. Adding a credit-reference-based financial vulnerability check is a planned improvement once a provider is appointed.

4. Act

4.1 Immediately, and automatically

When a marker is raised, three things happen straight away:

1. **The customer is contacted.** The next time they are on the site (dashboard or games), they see a supportive message suited to the marker. For example, for loss chasing: "*We noticed your stakes have been going up after a run of losses. Chasing losses is one of the most common ways gambling stops being fun…*". Every message includes GamCare's free

24/7 number.
    - The message stays until the customer responds. They can:
        - set a deposit limit (taken straight to Safer Gambling)
        - take a break
        - say they're OK
    - Their response is recorded.
2. **Marketing stops.** For 30 days after a marker, the customer receives no marketing or optional emails, unless staff review and dismiss the signal.
3. **Staff are alerted.** The Safer Gambling Lead receives an email alert linking to the signal.

4.2 Staff review

Every signal appears in the **Harm signals** queue (`/admin/harm-signals`). For each signal, staff see:

- what was observed and over what period
- the customer's deposits and stakes over the last 30 days
- the customer's other signals
- every past interaction with the customer

Staff decide what is proportionate, from light-touch to strong:

Step	When	How it's recorded
Record a note	The automated message is enough; watch for recurrence	Interaction (note)
Email or phone the customer	Medium or high severity, repeated signals, or no response to the automated message	Interaction (email / phone call), with a follow-up date
Apply a deposit limit	Spending looks unaffordable, or the customer agrees to one	Interaction (deposit limit applied). The platform only allows staff to *lower* a limit, never raise it.
Apply a cool-off	Signs of acute harm, or the customer asks	Interaction (cool-off applied)
Suspend the account	Serious concern, or no engagement after repeated interactions	Account status change with a reason (audited)
Close the account	Customer request, or strong evidence of harm	Account status change with a reason (audited)

Closing the review. Staff close the signal as **reviewed** or **dismissed**, with notes explaining what they found and decided. This is recorded in the admin audit log.

Target times:

- high-severity signals: reviewed within 24 hours
- all others: within 5 working days

Staff conduct. Staff never encourage further gambling, and never offer bonuses or incentives to a customer with an open signal. PlayStake does not currently run bonuses at all.

5. Evaluate

Automatic evaluation. Fourteen days after each interaction, the platform compares the customer's deposits and stakes in the 14 days before the interaction with the 14 days after, and records the outcome:

Outcome	Meaning
Customer took a break	A cool-off or self-exclusion was started after the interaction

Outcome	Meaning
Customer set a limit	A deposit limit was set or changed after the interaction
Behaviour improved	Deposits plus stakes fell to 75% or less of the previous 14 days
Behaviour unchanged	No meaningful change. **Staff are alerted to consider a stronger step.**

Manual outcomes. Staff can also record outcomes themselves, such as "escalated" or "no response".

6. Measuring effectiveness

The Harm signals page includes an effectiveness table. For each marker and each type of interaction, it shows how many interactions led to each outcome. Every quarter, the Safer Gambling Lead:

1. reviews the table, alongside complaint and self-exclusion trends
2. decides whether each automated message, threshold and staff response is working
3. adjusts thresholds, messages or escalation rules where it is not
4. records the conclusions and any changes in the quarterly board compliance report and in this policy's version history

7. Training

Everyone who works with customers or the admin tools is trained before starting, and every year after. The training covers:

- recognising the signs of gambling harm
- how to have a supportive conversation
- what the platform does automatically
- how to record interactions
- when to escalate

8. Records

These records are kept even if the customer's account is later deleted, for at least 5 years:

- signals
- interactions
- responses
- outcomes
- review notes

9. Review

Version	Date	Change
0.1	30 September 2026	First draft

Policy 06 — Age Verification

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually, and when an electronic verification provider is appointed
Relates to	Licensing objective 3 (protecting children); Gambling Act 2005 ss.46–47 (inviting or permitting a child or young person to gamble); LCCP social responsibility code 3.2.11 (remote age verification: verify age before a customer can deposit, access free-to-play games, or gamble); LCCP customer identity verification requirements

> Draft for review by a compliance adviser. LCCP references to be confirmed against the current version.

1. Purpose

Nobody under 18 may gamble with PlayStake. Remote operators must verify a customer's age **before** they can deposit, access free-to-play games, or gamble. This policy explains how PlayStake does that and what happens if an under-18 gets through.

2. Principles

- **Verify first.** Age is verified before any deposit, any free-to-play game, and any gambling. No product lets anyone play first and verify later.
- **Fail closed.** Anything short of full verification blocks all gambling.
- **No shortcuts.** Staff cannot mark a customer as age-verified without an approved identity document showing they are 18 or over. The platform enforces this.

3. How age is verified

3.1 At sign-up

- **Email sign-up.** Customers who sign up with email must give their date of birth and actively tick a box confirming they are 18 or over. The box also confirms that their age and identity will be checked before they can deposit or play. Anyone whose date of birth makes them under 18 is refused, and no account is created. The date of birth and the time of the confirmation are recorded.
- **Google sign-in.** Customers who sign in with Google do not give a date of birth at sign-up. They go through exactly the same identity verification (section 3.2) before they can deposit or play.
- **Marketing.** Marketing consent is a separate, unticked, optional box.

Sign-up does not verify age. It only stops an under-18 who admits their age from opening an account. Verification happens in section 3.2.

3.2 Identity and age verification (KYC)

Before any deposit, free-to-play access or gambling, the customer must complete identity verification. The steps are:

1. **Email address verified first.**
2. **Electronic verification with Didit (the normal route).** The customer completes Didit's hosted check, which:

- reads and checks the identity document for authenticity and tampering (passport, driving licence, national ID card or residence permit, from any country; expired documents are declined)
- runs a passive liveness check and matches the selfie to the document photo
- declines anyone the document shows is under 18
- checks a proof of address issued in the last 3 months (utility bill, bank statement or government letter)
- screens the customer against sanctions, PEP and adverse-media lists, and re-screens them as the lists change

PlayStake re-reads Didit's decision from Didit's API with its own key (never trusting a webhook body alone) and records it as a submission. Didit approves automatically only when every step passes; anything borderline (a possible AML match, a borderline face match, an unclear proof of address) comes back "In Review" for staff.

3. **Upload for manual review (fallback).** If Didit is unavailable, or the customer can't use it, they enter their legal name, date of birth and address, and upload a passport (photo page), a driving licence or national ID card (front and back), and a selfie.

   Automatic checks on an upload:

   - the date of birth entered must show the customer is 18 or over
   - files must be genuine images or PDFs (checked from the file contents, not the file name) and no larger than 8 MB
   - documents are encrypted as soon as they are received (AES-256-GCM)

4. **Identity screening:**

   - the document date of birth is compared with the one given at sign-up; a mismatch opens a case and blocks approval
   - the same name and date of birth, or the same document image, on another account opens a case and blocks approval (one person, one account)
   - GAMSTOP is checked (Policy 04)

5. **Decision.**

   - **Didit approved:** the customer is verified automatically only if the document date of birth shows they are 18 or over **and** no identity case is open. Otherwise the submission waits for staff.
   - **Didit declined:** rejected with Didit's reasons; the customer can try again.
   - **Didit in review, or any upload:** staff review it at `/admin/kyc`, seeing Didit's results (document, liveness, face match, proof of address, AML) and opening the session in Didit's console for the images. For an upload, the reviewer checks that:
   - the document is genuine and unaltered, and not expired
   - the name and date of birth on the document match what the customer entered
   - the selfie matches the document photo
   - the address is plausible and consistent

6. **Age re-checked at approval.** When the reviewer approves, the platform re-checks age from the document's date of birth. It refuses approval if the customer is under 18, and tells the reviewer to close the account as under-18 instead.

7. **Decision.** Every approval and rejection is recorded, with the reviewer and their notes, in the admin audit log. A rejection must include a reason, which the customer is told.

Electronic verification provider. Didit (didit.me) was appointed in October 2026 (Master Manual §8 item 4). Before real-money launch: sign Didit's data processing agreement, confirm where data is processed and stored, complete the DPIA (Document 17), and consider adding Didit's UK electoral-roll or credit-reference check so the address can be verified without a document.

3.3 Where verification is enforced

The eligibility check (Master Manual §5.1) requires verified identity for every one of these actions:

Action	Blocked until verified?
Depositing	Yes
Issuing or accepting a challenge (the only way to enter a match since the on-site games and lobby were withdrawn on 25 October 2026)	Yes
Having a stake locked when an opponent accepts a match	Yes (the opponent is re-checked)
Withdrawing	Yes
Applying to be a referee	Verified identity is required before approval and before officiating

Explaining the block. A notice on the games page tells an unverified customer they can't play yet and links to verification.

No manual override. Staff cannot set a customer to "verified" by hand unless an approved identity document shows they are 18 or over. The attempt is refused.

4. If an under-18 is found

An under-18 may be found in several ways: at verification, through a document review, a report from a parent, or information from a payment provider. Whenever it happens, staff act at once:

1. **Close the account as under-18** from the customer's admin page, giving a reason. The platform then automatically:
   - **voids every unsettled bet** they are party to, returning both players' stakes, because an under-18 cannot lawfully win or lose a bet
   - withdraws their lobby entries, invites and challenges
   - signs them out everywhere and prevents them signing in again
   - records the action, including their balance at the time and the voided bets, in the admin audit log
2. **Return their money.** The Head of Compliance arranges for the account's deposits to be returned to their source, outside the platform. Winnings are not paid.
3. **Review settled bets.** For bets that settled before the account was closed, the Head of Compliance reviews each one:
   - stakes the customer lost are returned as part of step 2
   - opponents who lost money to the under-18 are refunded by PlayStake where appropriate
   - every decision is recorded on the customer's record
4. **Consider reporting.** Decide whether to report to the Gambling Commission (for example, as a key event if a control failed) and whether safeguarding concerns need to be raised.
5. **Learn.** Establish how the customer got through verification, and fix the cause.

An under-18 closure **cannot be reversed**. Someone who has since turned 18 must open a new account and be fully verified.

5. Marketing and product design

- PlayStake's marketing is aimed only at adults. It does not use content, games, influencers or channels with particular appeal to under-18s.
- The site footer and every email footer state "18+ only", and the Terms of Service set 18 as the minimum age. Email footers also carry GamCare's free support number.
- Streamer partners on Kick must be over 18 and verified. Their PlayStake content must not target under-18s.

6. Monitoring and testing

The Head of Compliance carries out checks every quarter:

- **Sample check.** Re-check a sample of approved identity verifications against their documents.

- **Test the controls.** Confirm that an unverified test account cannot deposit, enter the games or stake. The automated test suite also checks this on every code change.

The results are included in the quarterly board compliance report.

7. Records

- **Identity documents:** kept encrypted for the retention period in the Privacy Policy. They are only ever decrypted when a reviewer deliberately opens them.
- **Verification decisions:** kept even if the account is deleted, and recorded in the audit log.
- **Under-18 closures:** permanent on the account.

8. Review

Version	Date	Change
0.1	30 September 2026	First draft

Policy 07 — Anti-Money Laundering and Counter-Terrorist Financing: Risk Assessment and Controls

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Money Laundering Reporting Officer (MLRO)
Version	0.1 — draft for licence application
Review	**At least annually**, and before launching any new product, game type, payment method or technology, or when a significant new risk or typology is identified (section 9)
Relates to	LCCP licence condition 12.1.1 (anti-money laundering: assess ML/TF risks and have appropriate policies, procedures and controls, reviewed as necessary and at least annually); Proceeds of Crime Act 2002 (POCA) Part 7; Terrorism Act 2000; sanctions regimes administered by OFSI; the Commission's guidance "*The prevention of money laundering and combating the financing of terrorism — guidance for remote and non-remote operators (excluding casinos)*"

> Draft for review by a compliance adviser. **Regulatory position:** as a non-casino operator, PlayStake is expected not to be a "relevant person" under the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017 (which apply to casino licensees). It is, however, fully subject to POCA, the Terrorism Act and the LCCP. PlayStake nevertheless applies customer due diligence, monitoring and record-keeping to a standard informed by the Regulations. *Confirm this position with legal advisers for the licence type applied for.*
>
> All monetary thresholds below are defaults in the platform, in pounds sterling. The platform switched from US dollars to GBP on 20 October 2026, while payments were still in Stripe test mode. The figures were kept as they were, not converted at an exchange rate. The MLRO must confirm each figure in this assessment before launch (Master Manual §8 item 9).

Part A — Risk assessment

A1. Method

The assessment works as follows:

1. **Identify risks.** Money laundering and terrorist financing risks are identified across six factors: customers, products and games, transactions, delivery channels, payment methods and geography.
2. **Rate inherent risk.** Each risk is rated for likelihood (Low, Medium or High) and impact (Low, Medium or High), before controls, giving an inherent risk.
3. **Rate residual risk.** Each risk is then rated again after PlayStake's controls, giving a residual risk.

Current assessment. It is based on the platform as built on 30 September 2026, before real-money launch. There is no live transaction history yet. The first review after launch must use real data (section 9).

A2. The business model and why it matters

PlayStake customers stake money against **each other** on games they play themselves. PlayStake holds both stakes in escrow and pays the winner, less a platform fee. It never takes a position.

This creates a risk that doesn't exist, or is much smaller, in house-banked betting: **value transfer between customers**. If two accounts are controlled by the same person, or by people acting together, one can deliberately lose to the other. That moves money from one account to another with a gambling transaction as cover. This is "chip dumping" (or "soft play"). The receiving account then withdraws the "winnings". It is the dominant money laundering typology for this business, and most of the controls in Part B are built around it.

A3. Risk register

#	Risk	Factor	Inherent (L × I)	Key controls (Part B)	Residual
1	**Chip dumping.** Colluding accounts pass value by losing on purpose.	Product / transactions	High × High = **High**	One-person-one-account screening (B2.3); chip-dumping detection (B3.1); head-to-head cap of 5 matches an hour (B3.2); shared-IP detection (B3.1); withdrawal holds (B4)	**Medium**
2	**Deposit-and-withdraw without play.** Criminal funds are deposited, lightly played or not played, and withdrawn as apparently legitimate funds.	Transactions	Medium × High = **High**	Deposit-and-withdraw-without-play detection and a real-time withdrawal hold (B3.1, B4); payouts only to a verified bank account (B4)	**Low–Medium**
3	**Spending the proceeds of crime.** A customer gambles with criminal property, a "lifestyle" risk.	Customers / transactions	Medium × High = **High**	Customer due diligence (CDD) before any deposit (B2); EDD and source of funds over the 30-day threshold (B2.4); affordability markers (Policy 05); per-transaction deposit cap	**Medium**
4	**Stolen payment methods.** Deposits are made with stolen or compromised cards.	Payment methods	Medium × Medium = **Medium**	Stripe card processing, with 3-D Secure as Stripe applies it by default; chargeback suspension and case (B3.3); *explicit 3-D Secure rules and Stripe Radar rules outstanding*	**Medium** (Low once Radar is live)
5	**Mule and multiple accounts.** Accounts are opened in other people's names, or one person runs several.	Customers	Medium × High = **High**	Document KYC with selfie and manual review; shared-identity and document-image matching; DOB cross-check; shared-IP detection; *electronic ID with liveness outstanding*	**Medium**
6	**Result manipulation to move value.** A referee or a player fixes a result.	Product	Medium × High = **High**	Independent referees who are verified, approved per game and never officiate their own matches; hash-chained referee audit; dispute window; overturn tracking; anomaly detection	**Low–Medium**
7	**Sanctioned persons and PEPs.**	Customers	Low × High = **Medium**	*Screening provider outstanding.* Interim: manual check against the OFSI consolidated list at KYC approval (B2.5).	**Medium**, falling to Low once automated
8	**Terrorist financing.** Small value transfers, including through the P2P mechanism.	Transactions	Low × High = **Medium**	The same controls as risks 1, 2 and 7; the MLRO reports under the Terrorism Act	**Low**
9	**Geography.** Customers or funds from high-risk or non-GB jurisdictions.	Geography	Medium × Medium = **Medium**	Country captured at KYC and reviewed at approval; *outstanding for launch: a GB-only restriction, a geolocation check, and automatic refusal of FATF high-risk jurisdictions*	**Low–Medium**
10	**Insider facilitation.** Staff approve identities improperly, lift restrictions or ignore alerts.	Delivery	Low × High = **Medium**	Staff 2FA; append-only admin audit log; platform-enforced limits on staff actions; quarterly independent review of cases	**Low**
11	**Streamer and audience channel.** Viewers on Kick challenge streamers; a streamer's audience could be used to channel funds.	Delivery channel	Medium × Medium = **Medium**	All the same controls apply to streamer challenges (it is the same lobby and escrow); referee oversight; head-to-head cap; chip-dumping detection	**Low–Medium**

Overall residual risk: Medium. This is driven by risks 1, 3 and 5. It is expected to fall once the outstanding provider-based controls (electronic ID, sanctions/PEP screening, Stripe Radar) are live, and after the first review based on live data.

Part B — Policies, procedures and controls

B1. Roles

- **The MLRO**, [COMPLIANCE LEAD NAME]:
  - owns this assessment
  - decides AML cases
  - makes Suspicious Activity Reports (SARs) and Defence Against Money Laundering (DAML) requests to the NCA
  - trains staff
  - reports to the board every quarter
- **All staff** must report any knowledge or suspicion of money laundering to the MLRO promptly. They can do this by adding a note to a case in the AML queue, or by telling the MLRO directly. Failing to report is an offence under POCA s.330.

B2. Customer due diligence

B2.1 Before any deposit

Identity is verified before any deposit, any play and any withdrawal (Policy 06):

- legal name, date of birth and address
- a photo identity document and a selfie
- manual review by trained staff

B2.2 Ongoing monitoring

- The monitoring in B3 runs on every account.
- Customers' circumstances are reviewed whenever a case is raised.

B2.3 One person, one account

At KYC, the new submission is matched against every other account:

- **Same legal name and date of birth, or the same document image** → a `SHARED_IDENTITY` case, and approval is blocked.
- **Document date of birth differs from the one given at sign-up** → a `DOB_MISMATCH` case, and approval is blocked.

B2.4 Enhanced due diligence (EDD) and source of funds

- **Trigger:** completed deposits over any 30 days at or above **5,000.00** (setting `AML_EDD_THRESHOLD_CENTS`). This opens a `HIGH_DEPOSIT_VOLUME` case.
- **What the MLRO obtains:** evidence of source of funds, such as payslips, bank statements or other documents appropriate to the amount, and, where needed, source of wealth.
- **What happens meanwhile:**
  - while the case is open, withdrawals are held (B4)
  - the MLRO may suspend the account if evidence is not provided within [14] days
- **Other EDD triggers:** EDD also applies when a customer:
  - is a PEP or connected to one (once screening is live)
  - is linked to a high-risk jurisdiction
  - is the subject of any high-severity case

B2.5 Sanctions and PEPs

Outstanding. A screening provider is to be appointed.

Interim control. Until then, at KYC approval the reviewer checks the customer's name and date of birth against the OFSI consolidated list, and notes the check in the review notes.

If a customer is a sanctions match:

1. do not approve the account
2. freeze their funds
3. report to OFSI
4. inform the MLRO

B3. Transaction monitoring

A scan runs **every 15 minutes**. Its results are cases in the **AML queue** (`/admin/aml`), and each new case alerts the MLRO by email.

B3.1 Automated detectors

Detector	Case type	Triggered when	Severity
Chip dumping	`CHIP_DUMPING` (receiver, with the sender linked)	The same two players played **5 or more** times in 7 days, one side won **80% or more** of decided games, and received at least **100.00** net (`AML_CHIP_DUMP_VALUE_CENTS`)	Medium; high at 10+ games or 5× the value
Shared IP, played each other	`SHARED_IP` (both linked)	Two accounts used the same IP address in the last 30 days **and** wagered against each other	High
Many accounts on one IP	`SHARED_IP`	Four or more accounts on one IP address in 30 days	Low (for review; households and public networks are common)
Deposit and withdraw without play	`DEPOSIT_WITHDRAW_NO_PLAY`	Deposits of at least **50.00** in 7 days (`AML_NO_PLAY_MIN_DEPOSIT_CENTS`), at least half withdrawn within 24 hours, and less than a quarter of the deposits staked	Medium
Deposits over the EDD threshold	`HIGH_DEPOSIT_VOLUME`	See B2.4	Medium; high at 2×
Identity	`SHARED_IDENTITY`, `DOB_MISMATCH`	See B2.3	High / Medium
Chargeback	`CHARGEBACK`	A card issuer dispute on a deposit	High

Signal frequency. Only one open case exists per customer, type and counterparty, so a continuing pattern doesn't flood the queue.

B3.2 Preventive controls

- **Head-to-head cap.** The same two customers can play each other at most **5 times in any hour**. Further matches are refused.
- **No self-play.** The database refuses a bet between an account and itself.
- **Deposit caps.** Each deposit must be between 5.00 and 1,000.00.

B3.3 Chargebacks

A card dispute on a deposit has two immediate effects:

- the account is **suspended**, so no stakes or withdrawals can be made
- a high-severity case is opened for the MLRO

B4. Withdrawal controls

Withdrawals are where laundered funds leave. A withdrawal request is **held for review**, and not paid, when any of these apply:

Condition	What happens
The account is suspended or closed	The withdrawal is refused
A **medium- or high-severity** AML case is open on the account	The withdrawal is held. Low-severity cases, such as a shared household IP, do not hold money.
The amount is at or above **2,000.00** (`AML_WITHDRAWAL_REVIEW_THRESHOLD_CENTS`)	A review case is opened and the withdrawal is held
The withdrawal follows deposits with little play (the B3.1 rule, counting the requested amount)	A `DEPOSIT_WITHDRAW_NO_PLAY` case is opened and the withdrawal is held

Customer message. The customer is told only that the withdrawal "needs a quick review" and that their balance is safe. They are never told about a suspicion.

Clearing a hold. When the MLRO closes the case with **no suspicion**, withdrawals of the same kind go through for the following 7 days.

Where payouts go. Payouts go only to the customer's own bank account, verified through the payment provider (Stripe Connect), after identity and email verification. *Outstanding: automatically matching the payout account holder's name to the verified legal name. Until then, the MLRO checks this manually for any held withdrawal.*

Exclusion never traps funds. Self-exclusion and GAMSTOP registration never block a withdrawal (Policies 03 and 04). Only AML and fraud controls do.

B5. Case handling and suspicious activity reporting

Every AML case is worked in the AML queue:

1. **Assign.** The investigator or MLRO takes the case.
2. **Investigate.** Review the customer's identity, transactions, betting pattern, counterparties and linked cases. Record notes on the case.
3. **Decide.** The MLRO records the reasoning for every decision on the case. The platform requires it. The decision is one of:
   - **close, no suspicion:** releases held withdrawals of that kind for 7 days
   - **close, action taken:** for example, the account was suspended or closed, or winnings were withheld under the Terms
   - **escalate to the MLRO:** where an investigator has worked the case
   - **SAR submitted:** the MLRO records the NCA reference on the case
4. **Report.** Where the MLRO knows or suspects money laundering or terrorist financing, or has reasonable grounds to, they make a SAR to the NCA through the SAR Online portal as soon as practicable. Where PlayStake would otherwise pay out or process funds it suspects are criminal property, the MLRO requests a **DAML** first, and the funds stay held (the withdrawal hold) until consent is given or the statutory period ends. Every SAR decision is recorded, including decisions *not* to report and why.

5. **Don't tip off.** Nobody may tell the customer, or anyone else, that a SAR has been considered or made, or that an investigation is under way (POCA s.333A). The customer-facing messages are written with this in mind. The AML case page reminds staff.
6. **Notify the Commission** where the LCCP requires it. SARs themselves are not shared with the Commission except as the law allows.

Every action on a case is recorded in the append-only admin audit log.

B6. Record keeping

The following are kept for **at least 5 years** after the business relationship ends, or after the transaction for occasional transactions:

- CDD records and documents
- transaction and ledger records (the double-entry ledger is immutable by design)
- AML cases and their notes and decisions
- SAR decisions and references

These records are protected from deletion with the customer's account. SAR-related records are held so that they can be produced to the NCA or the courts when required.

B7. Training

All staff receive AML training before starting and every year after. It covers:

- the offences (POCA ss.327–330 and s.333A; the Terrorism Act)
- PlayStake's typologies, especially chip dumping
- red flags
- how to report to the MLRO
- tipping off

The MLRO keeps training records and tests understanding.

B8. Governance

The MLRO reports every quarter to the board on:

- case volumes by type
- time to decision
- SARs and DAMLs (numbers only)
- withdrawal holds
- any control weaknesses

The quarterly independent review (Master Manual §3) samples closed cases.

Part C — Review triggers

This assessment is reviewed **at least annually**, and before or immediately after any of these:

- a new product, game type or match type (for example, a new third-party game category)
- a new payment method, currency or payout route, including the move from test mode to live payments in GBP
- new technology, such as a new identity or verification provider, or a change to how results are determined
- entering a new market or jurisdiction
- a significant change in volumes or customer behaviour, or a new typology seen in cases or in Commission or NCA publications

- a material control failure, or findings from the independent review

The first live-data review must be carried out **3 months after real-money launch**. It will re-rate each risk using real transaction data and recalibrate the thresholds in B2.4, B3.1 and B4.

Version history

Version	Date	Change
0.1	30 September 2026	First draft, pre-launch assessment

Document 08 — System Diagram and Outsourcing Map

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance (with engineering)
Version	0.1 — draft for licence application
Review	On any new supplier, hosting change or new product; at least annually
Relates to	Remote operating licence application: system diagram with commentary; LCCP 15.2.1 key events (outsourcing of key functions); RTS security requirements (Document 13)

> Draft prepared from the platform as built on 30 September 2026. Items in `[BRACKETS]` must be completed before submission. Where a supplier is "planned", no contract exists yet and the function is not live.

1. Purpose

This document gives the Commission a single picture of the PlayStake gambling system: every component, who provides and operates it, where it runs, and how data and money flow between components. It also lists every function we rely on a third party for (the outsourcing map). Document 09 follows a customer through the system end to end. Document 10 maps each activity to its location, provider and operator.

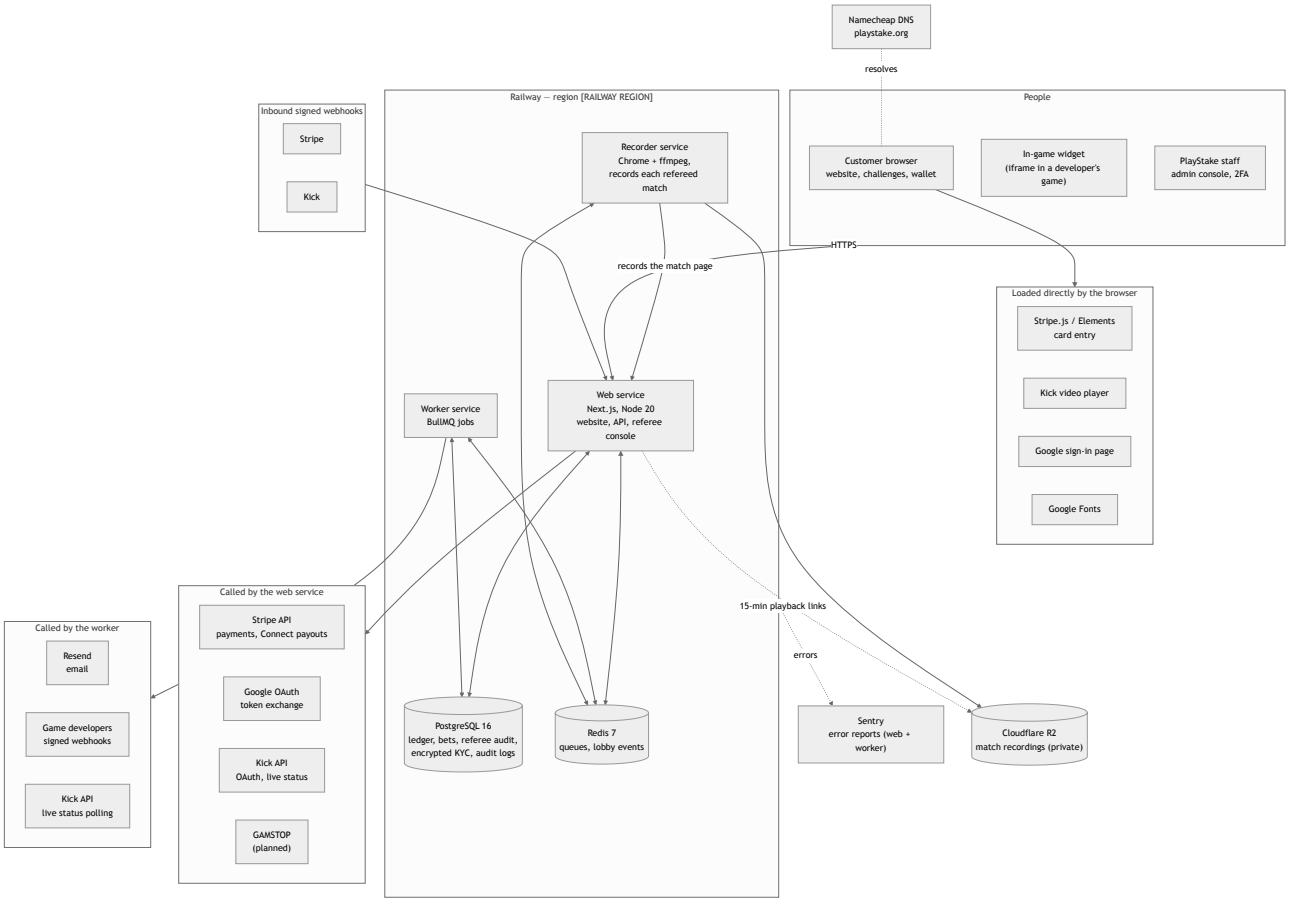
2. Summary

PlayStake is a single web application with a separate background-worker process, a PostgreSQL database and a Redis instance. All four are hosted by one provider (Railway). PlayStake writes and operates all of its gambling software itself: challenges and match management, the referee console, the wallet and ledger, result handling, and all compliance controls. No third-party gambling software or platform is used. The games themselves (EA SPORTS FC 27 and Tekken 8) are third-party console and PC games that players run on their own devices; PlayStake does not host, run or modify them, and uses no random number generator.

A third service, the **recorder**, records every refereed match: it opens a private PlayStake page showing both players' and the referee's Kick streams, captures it with sound, and stores the sealed video in Cloudflare R2 (Document 18).

Third parties provide: card payments and payouts (Stripe), match-recording storage (Cloudflare R2), transactional email (Resend), error monitoring (Sentry), optional sign-in (Google), live-stream integration (Kick), domain name registration and DNS (Namecheap), source control and build checks (GitHub). The national self-exclusion check (GAMSTOP) and dispute resolution (IBAS) are contracted but not yet live.

3. System diagram



3.1 Commentary

- **The recorder.** A third service, from the same code, takes a recording job from Redis when a referee starts a match, records the private match page in Chrome with ffmpeg, uploads 5-minute pieces to R2 while recording, and seals the final file into the audit trail when the result is recorded (Document 18).
- **One application, two processes.** The web service answers every request from customers, staff and game developers. The worker service runs everything time-based: settlement after the dispute window, expiry of unanswered bets, no-show voiding, dispute escalation, anomaly and harm detection, AML scans, the daily ledger audit, email delivery, outbound webhooks, deposit-limit activation and session cleanup. Both processes are deployed from the same code and connect to the same database.
- **The database is the system of record.** Balances exist only as ledger accounts in PostgreSQL, changed only through a double-entry `transfer()` that writes two balancing entries. Ledger entries, the admin audit log, referee audit events and the historical game events of the withdrawn on-site games cannot be edited or deleted (database triggers reject it).
- **No games run on our servers.** Every match is played in a third-party game on the players' own devices and streamed on Kick. An independent human referee decides the result from both streams through the referee console. PlayStake's own on-site games and their random number generator were withdrawn on 25 October 2026. See Document 11 for testing.
- **Card data never reaches PlayStake.** Card entry uses Stripe Elements, loaded from Stripe, so PlayStake never sees or stores card numbers. Stripe tells us about payments through signed webhooks, which are verified before any balance changes.
- **Redis holds no money and no customer records.** It carries job queues, real-time lobby events and the worker heartbeat. Losing it delays background work; it does not lose funds or records.
- **Identity documents** are stored in PostgreSQL encrypted with AES-256-GCM, under a key held only in the hosting environment. Every staff view is logged.

4. Outsourcing map

"Operated by" is who runs the service day to day. "Data shared" is what leaves PlayStake. Every supplier is a key supplier in the sense of LCCP 15.2.1 unless marked otherwise; changes are notified as key events (Document 14).

Function	Supplier	Status	What they do	Data shared	Where processed	Contract / assurance
Hosting and storage	Railway Corp.	Live	Runs the web, worker and recorder services, PostgreSQL and Redis; database backups (to be confirmed as enabled, Document 13)	All platform data (hosted, not accessed by Railway for its own purposes)	Railway EU West — `europe-west4` (Amsterdam, Netherlands), all five services (checked 27 October 2026)	Railway terms and DPA. [CONFIRM SOC 2 REPORT]
Match-recording storage	Cloudflare, Inc. (R2)	Live from 27 October 2026 (DPIA sign-off outstanding, Document 18)	Stores sealed match recordings privately; deleted after 30 days, or 12 months after a dispute is decided	Video and sound of players' and referees' streams	R2 bucket with **EU jurisdiction**; no public access	Cloudflare DPA (with UK addendum). Document 18
Payment services	Stripe Payments Europe / Stripe, Inc.	Live, **test mode**	Card deposits (Payment Intents), withdrawals via Stripe Connect Express, Radar fraud screening (to configure)	Customer name, email, amount; card data handled by Stripe only	Stripe (EU/US)	Stripe Services Agreement; PCI DSS Level 1; PSR authorisation and approved methods in Policy 16
Age and identity verification	Didit (didit.me)	Live (normal route)	Hosted identity check: document authenticity, liveness, face match, age (18+), proof of address, AML screening and ongoing re-screening	Name, date of birth, address, document and selfie images (biometric), email, PlayStake user id	EU (Spain); processing and storage locations to confirm	ISO 27001, SOC 2 Type II; DPA to sign; DPIA in Document 17
	In-house	Live (fallback)	Customers who can't use Didit upload an identity document; staff review it before any deposit or gambling	—	PlayStake (Railway)	—
Sanctions and PEP screening	[SCREENING PROVIDER]	Planned	Screening at verification and on list updates	Name, date of birth, nationality	[TBC]	To contract (Master Manual §8 item 5)
Multi-operator self-exclusion	GAMSTOP (The National Online Self Exclusion Scheme Ltd)	Planned	Checks every customer against the national register	Name, date of birth, email, postcode	UK	Membership to complete (Master Manual §8 item 3)

Function	Supplier	Status	What they do	Data shared	Where processed	Contract / assurance
Geolocation	None	**Gap**	No IP-based location check today. Customers state their country at verification.	—	—	See §6
Fraud detection	In-house	Live	Anomaly detection (win rates, winner patterns, fast settlement, volume spikes), shared-identity checks, AML scans	—	PlayStake	—
	Stripe Radar	To configure	Card-fraud scoring on deposits	As payment services	Stripe	As payment services
Customer service	In-house, on Google Workspace email	Live	support@playstake.org (Google Workspace mailbox), complaints procedure, in-app messages	Customer emails	Google	Google Workspace terms and DPA
Alternative dispute resolution	IBAS	To sign	Independent adjudication of unresolved complaints	Complaint file, on referral only	UK	ADR agreement (Master Manual §8 item 2)
Marketing	None	—	No marketing providers, affiliates or ad networks	—	—	—
Website analytics	Google (Google Analytics 4)	Live, only with consent	Page views on public marketing pages, loaded only after the visitor accepts analytics cookies; no analytics inside the signed-in app	Pseudonymous cookie ID, page visited, device and approximate location	Google	Google Ads Data Processing Terms
Transactional email	Resend	Live	Sends account, bet, safer-gambling and complaint emails from an outbox	Email address, name, message content	[RESEND REGION]	Resend terms and DPA
Error monitoring	Functional Software (Sentry)	Optional, live when `SENTRY_DSN` set	Receives error reports; session replay disabled	Error context (may include user ID)	EU (Germany) — `ingest.de.sentry.io`	Sentry terms and DPA
Sign-in	Google (OAuth)	Live, optional	Lets customers sign in with a Google account	Email, name (from Google)	Google	Google API terms
Live streaming	Kick	Live	Channel linking (OAuth), live status, webhooks, embedded video player for stream matches	Kick channel ID and tokens (tokens encrypted at rest)	Kick	Kick developer terms
Domain and DNS	Namecheap	Live	Registers playstake.org and serves its DNS	None	Namecheap	Namecheap terms

Function	Supplier	Status	What they do	Data shared	Where processed	Contract / assurance
Source control and build checks	GitHub (Microsoft)	Live	Hosts source code; runs tests, dependency audit and malware scan on each change	Source code only; no customer data	GitHub	GitHub terms
Web fonts	Google Fonts	Live	Serves font files to browsers	Visitor IP address (to Google)	Google	Google terms. Consider self-hosting (§6).
Game developers (widget integrations)	Each developer	Live	Receive signed bet-lifecycle webhooks for their own games	Bet IDs, amounts, outcomes for their game	Developer's systems	Developer terms

5. What is not outsourced

- All gambling software: challenges and match management, the wallet and double-entry ledger, escrow, settlement, result verification, disputes and the referee console. (PlayStake runs no game logic or random number generation of its own.)
- Every compliance control: eligibility gate, deposit limits, breaks and self-exclusion, reality checks, customer interaction, AML scans, complaints handling, audit logging.
- Customer data processing: it runs only in PlayStake's own services on Railway.

6. Gaps and actions

#	Gap	Action	Needed for
1	Hosting region not recorded	Confirm the Railway region for each service and the backup location; record here and in Document 10	Application
2	No geolocation control	Decide permitted jurisdictions. Put an IP-geolocation layer in front of the service (for example a CDN that supplies a country header), block prohibited locations at sign-up, deposit and staking, and restrict verification to permitted countries of residence.	Launch
3	Planned suppliers not contracted	GAMSTOP, IBAS, eIDV and sanctions/PEP screening	Application / launch as marked
4	Supplier assurance not on file	Collect SOC 2 / ISO 27001 reports or equivalent from Railway, Stripe, Resend, Sentry; record DPAs	Application
5	Third-party fonts	Self-host fonts so no visitor data goes to Google	Recommended

7. Review

The Head of Compliance keeps this map current with engineering. Any new supplier, removal of a supplier, or change of hosting is reviewed before it goes live, reflected here, and assessed as a possible key event (Document 14).

Version	Date	Change
0.1	30 September 2026	First draft

Document 09 — End-to-End Customer and System Flow

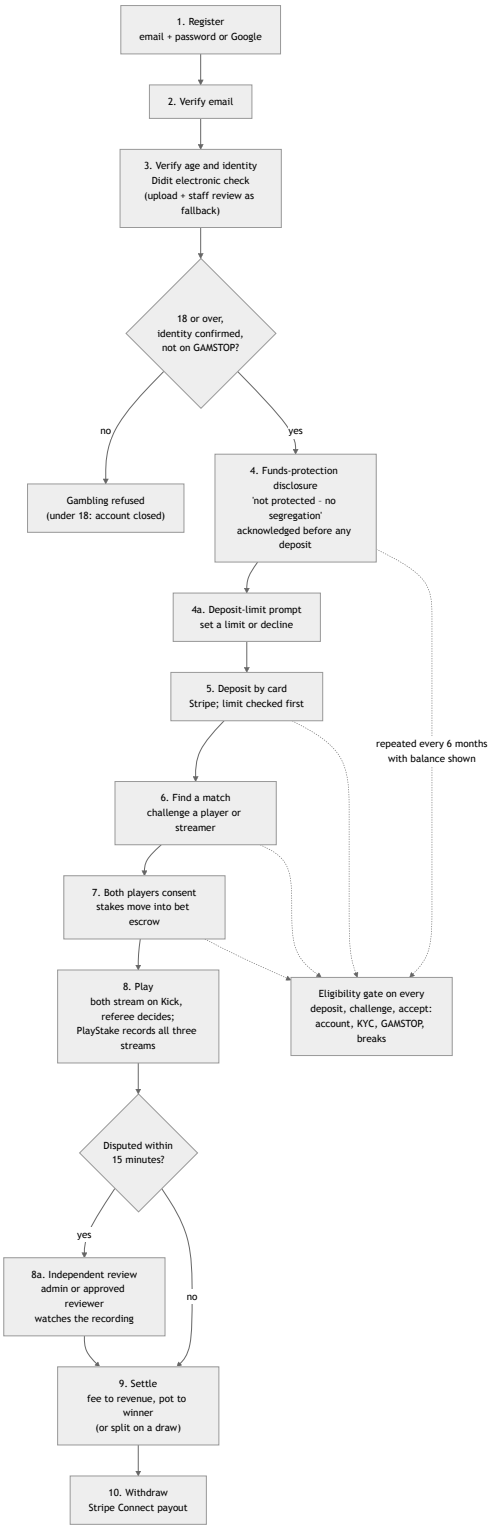
Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance (with engineering)
Version	0.1 — draft for licence application
Review	On any change to registration, verification, payments, games or settlement; at least annually
Relates to	Remote operating licence application: end-to-end diagram including the location of remote gambling equipment; Documents 08 and 10

> Draft prepared from the platform as built on 30 September 2026. `[BRACKETS]` must be completed before submission.

1. Purpose

This document follows a customer from registration to gambling to getting their money out, showing at each step which system does the work, which checks apply, and where the equipment is. Remote gambling equipment in the sense of the Gambling Act 2005 — the servers that register customers, record stakes, decide results and hold the wallet — is the PlayStake web service, worker service and PostgreSQL database, all hosted by Railway in its **EU West region (`europe-west4`, Amsterdam, Netherlands)** (Document 10 §3).

2. The journey at a glance



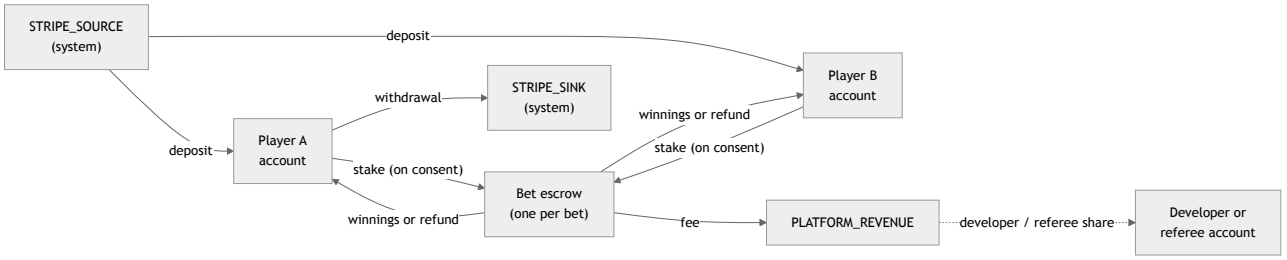
3. Step by step

All PlayStake steps run on the web service or worker service with data in PostgreSQL, hosted by Railway, unless another location is given. Railway region: EU West (`europe-west4`, Amsterdam, Netherlands).

Step	What happens	Controls	System and location
1. Register	Customer creates an account with email and password, or signs in with Google. Terms, privacy and 18+ confirmed.	Password strength rules; bcrypt hashing; rate limits on registration and sign-in; lockout after repeated failures	Web service (Railway). Google sign-in: Google.
2. Verify email	A link is emailed. Identity verification can't be started until the email is verified, so nobody can deposit or gamble with an unverified address.	Single-use, expiring token	Email sent through Resend from the worker's outbox
3. Verify age and identity	Customer completes Didit's hosted check: identity document, selfie with liveness, proof of address. Didit checks the document, matches the face, reads the date of birth and screens against sanctions, PEP and adverse-media lists. PlayStake re-reads the decision from Didit's API and runs its own checks (date of birth, same identity on another account). Borderline results go to staff. Customers who can't use Didit upload documents for staff review instead.	Under-18s declined; automatic approval only when every step passes and no identity case is open; fallback documents encrypted (AES-256-GCM) at rest; every staff view logged; decision and reason recorded. No deposit, free play or gambling before approval.	Didit (EU, Spain). Decisions and fallback documents: web service + PostgreSQL (Railway).
3a. GAMSTOP *(planned)*	The verified identity is checked against GAMSTOP on verification, on sign-in and when a cached result is over 24 hours old.	Registered customers can't gamble; a failed check refuses gambling rather than allowing it	GAMSTOP API (UK)
4. Funds-protection disclosure	Before any deposit the customer reads, in writing, that PlayStake's customer-funds rating is "not protected – no segregation" and what that means, and ticks to acknowledge it. The statement is repeated on every deposit, and at least every six months a reminder showing the funds held for them must be acknowledged before they can stake.	LCCP 4.2.1. Deposits and stakes refused until the current wording is acknowledged; version and time recorded. Policy 19.	Web service (Railway)
4a. Deposit-limit prompt	Before the first deposit the customer must set a deposit limit or actively decline. Every six months they are reminded to review limits.	Limits are on gross deposits, per day/week/month; decreases apply at once, increases after 24 hours	Web service (Railway)
5. Deposit	Customer pays by card on a Stripe form. Stripe confirms payment by signed webhook; the ledger then moves funds from `STRIPE_SOURCE` to the player's account.	Eligibility gate; deposit limits (most restrictive applies); affordability and AML thresholds; webhook signature verified; idempotent ledger transfer	Card entry: Stripe. Webhook handling and ledger: Railway.
6. Find a match	Customer challenges another player, or a live streamer, to EA SPORTS FC 27 or Tekken 8 and picks a stake (£1 to £500). The fee and what a win or draw pays are shown before commitment.	Eligibility gate on issuing and accepting a challenge, for both players; Match Rules accepted before the first challenge; unanswered challenges expire	Web service; real-time challenge events through Redis (Railway)
7. Consent and escrow	Each player explicitly consents. Only then is their stake moved from their account into a per-bet escrow account.	Sufficient-funds check in the same database statement as the debit; no stake taken without consent; unanswered bets expire and refund	Ledger in PostgreSQL (Railway)
8. Play	Both players stream their own screen on Kick. An independent, approved referee watches both streams and records the result (a win for either player, or a draw) with written notes.	Players can't declare results; the referee can't officiate their own match or players they follow, are followed by or have a block with; every referee action is written to a hash-chained, append-only audit trail; no referee within 10 minutes, or not finished within 2 hours, cancels the match with stakes returned in full; a player who drops and doesn't return within 10 minutes may lose the match on the referee's decision	Referee console: web service (Railway). Stream video: Kick.

Step	What happens	Controls	System and location
8a. Recording	From the moment the referee starts the match until the result, PlayStake's recorder captures both players' and the referee's streams, with sound and the match clock, into one video. Its SHA-256 fingerprint is sealed into the referee audit trail.	Recording page opened only with a signed token; stored privately; deleted after 30 days, or 12 months after a dispute is decided (Document 18)	Recorder service (Railway); storage: Cloudflare R2 (EU)
8b. Dispute	Either player can dispute within 15 minutes, pointing to moments in the match. An admin or an approved dispute reviewer decides it: never a player, the match referee, or anyone linked to a player by a follow or block. They take the dispute (so only one person decides), watch the recording and give written reasons.	Conflict checks; claims and decisions in the hash-chained audit trail and admin audit log; every viewing of a recording logged	Web service (Railway); recording from R2
9. Settle	The fee goes to `PLATFORM_REVENUE`, any developer or referee share is paid, and the rest of the escrow goes to the winner (or is split on a draw). Escrow must end at exactly zero.	Stream matches settle only after the dispute window; mismatched results open a dispute; settlement worker takes a row lock; daily ledger audit checks every account and transaction balances	Worker service or web service (Railway)
10. Withdraw	Customer onboards to Stripe Connect Express once, then requests a withdrawal. The ledger debits their balance to `STRIPE_SINK` and Stripe pays out to their bank.	Verified identity required; suspended accounts can't withdraw; self-excluded and GAMSTOP-registered customers **can** withdraw; payout account name to be matched to the verified name	Ledger: Railway. Payout: Stripe.

4. Money flow



Every arrow is one call to the ledger's `transfer()`, which writes one debit and one matching credit and can never leave an account (other than the three system accounts) below zero.

5. Where the equipment is

Component	Provider	Location
Web service (website, API, referee console)	Railway	EU West, `europe-west4` (Amsterdam, Netherlands)
Worker service (settlement, expiry, detection, email, webhooks, recording retention)	Railway	EU West, `europe-west4`
Recorder service (records each refereed match)	Railway	EU West, `europe-west4`
PostgreSQL (all records, ledger, encrypted KYC documents)	Railway	EU West, `europe-west4`
Database backups	Railway	[BACKUP LOCATION — confirm in Railway]
Redis (queues, challenge events)	Railway	EU West, `europe-west4`

Component	Provider	Location
Match recordings	Cloudflare R2	EU jurisdiction bucket
Identity checks	Didit	EU (Spain)
Card processing and payouts	Stripe	Stripe data centres (EU/US)
Email delivery	Resend	[RESEND REGION]
Error monitoring	Sentry	EU (Germany)
Live video	Kick	Kick

No remote gambling equipment is located in Great Britain: all of it is in Railway's EU West region in the Netherlands. The Commission must be told where remote gambling equipment is and of any change (Document 14).

Version	Date	Change
0.1	30 September 2026	First draft
0.2	27 October 2026	Didit identity checks; funds-protection disclosure; match recording and independent dispute review; Railway region recorded (EU West, Netherlands)

Document 10 — Operational Model Map

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	On any change of supplier, location, staff role or activity; at least annually
Relates to	Remote operating licence application: operational model (location, provider and operator of all systems and activities, including key equipment); Documents 08, 09

> Draft prepared from the platform as built on 30 September 2026. `[BRACKETS]` must be completed before submission.

1. Purpose

For every system and every business activity, this map states where it happens, who provides it and who operates it. "Provider" is whoever supplies the system or service. "Operator" is whoever runs it and makes the decisions. Document 08 has the system diagram and the full outsourcing detail.

2. Operating model in one paragraph

PlayStake is operated by [COMPANY NAME] from [OPERATING ADDRESS]. The company builds and runs its own gambling software. The software runs on cloud infrastructure rented from Railway in its EU West region (`europe-west4`, Amsterdam, Netherlands); PlayStake staff deploy and administer it. Payments are processed by Stripe. All customer-facing decisions — verification, limits, interactions, complaints, disputes, suspensions, AML — are made by PlayStake staff through the PlayStake admin console. At launch one person, [COMPLIANCE LEAD NAME], holds the compliance, MLRO and operations roles (Master Manual §3).

3. Key equipment

Equipment	Purpose	Provider	Operator	Location
Web service (Next.js, Node 20)	Website, customer and staff interfaces, API, referee console, payment webhooks. No game logic or random number generation (on-site games withdrawn 25 October 2026)	Railway (infrastructure); PlayStake (software)	PlayStake	EU West, `europe-west4` (Netherlands)
Worker service (BullMQ)	Settlement, expiry and no-show handling, dispute escalation, harm and anomaly detection, AML scans, ledger audit, email and webhook delivery, session cleanup	Railway; PlayStake	PlayStake	EU West, `europe-west4` (Netherlands)
PostgreSQL 16	System of record: accounts, ledger, bets, referee audit trail, encrypted identity documents, compliance and audit records; historical game records of the withdrawn on-site games (append-only, no new rows)	Railway	PlayStake	EU West, `europe-west4` (Netherlands)
Database backups	Recovery of the system of record	Railway	PlayStake	[BACKUP LOCATION] — confirm backups are enabled and tested (Document 13)
Redis 7	Job queues, real-time lobby events, worker heartbeat	Railway	PlayStake	EU West, `europe-west4` (Netherlands)

Equipment	Purpose	Provider	Operator	Location
Recorder service (Chrome, ffmpeg)	Records every refereed match: both players' and the referee's streams with sound and match clock, sealed into the audit trail	Railway; PlayStake	PlayStake	EU West, `europe-west4` (Netherlands)
Match-recording storage	Private store of sealed recordings, deleted on schedule	Cloudflare (R2)	PlayStake	EU jurisdiction
Domain and DNS (playstake.org)	Customer access	Namecheap	PlayStake	Global DNS
Source code repository and CI	Change control, automated tests, dependency audit, malware scan	GitHub	PlayStake	GitHub (US)
Staff devices	Administration	[COMPANY / STAFF]	PlayStake staff	[STAFF LOCATIONS]

4. Activities

Activity	Where it is done	Provider	Operator	Notes
Customer registration	Web service	PlayStake	PlayStake	Optional Google sign-in (Google)
Age and identity verification	Didit hosted check; web service; admin console	Didit (electronic checks); PlayStake	PlayStake (decisions); staff review borderline cases and the upload fallback	Didit in the EU (Spain); DPIA Document 17
GAMSTOP checks	Web service → GAMSTOP	GAMSTOP	PlayStake	Planned
Sanctions and PEP screening	Admin console (manual); planned supplier	[SCREENING PROVIDER]	PlayStake (MLRO)	Manual check against OFSI list until contracted
Deposits	Stripe (card capture); web service (ledger)	Stripe	PlayStake	Stripe in test mode until launch
Withdrawals	Web service (ledger); Stripe Connect (payout)	Stripe	PlayStake	
Challenges and match management	Web service, Redis	PlayStake	PlayStake	
Game play	Players' own consoles or PCs; third-party games (EA SPORTS FC 27, Tekken 8)	Game publishers	Players	PlayStake runs no games and no random number generation since 25 October 2026
Stream-match refereeing	Referee console; Kick video	PlayStake (software); Kick (video)	Independent referees engaged by PlayStake	Referees vetted and audited (Policy 01)
Match recording	Recorder service; Cloudflare R2	PlayStake; Cloudflare	PlayStake	Every refereed match; DPIA Document 18
Result verification and disputes	Web service, worker; admin console; reviewer pages	PlayStake	Admins, or referees approved as independent dispute reviewers	Reviewer can't be a player, the match referee, or linked to a player by a follow or block
Customer funds protection disclosure	Web service	PlayStake	PlayStake	Rating "not protected – no segregation"; acknowledged before deposit and six-monthly (Policy 19)

Activity	Where it is done	Provider	Operator	Notes
Settlement and payouts to balances	Worker service / web service	PlayStake	PlayStake	
Safer gambling: limits, breaks, reminders, interactions	Web service, worker; admin console	PlayStake	PlayStake staff	Policies 03–05
AML monitoring and case management	Worker; admin console	PlayStake	MLRO	Policy 07
Fraud and anomaly detection	Worker; admin console	PlayStake (Stripe Radar planned)	PlayStake staff	Policy 01
Customer service	Email (support@playstake.org)	Google Workspace	PlayStake staff	
Complaints	Website form; admin console	PlayStake	Complaints manager	Policy 02
ADR	IBAS	IBAS	IBAS	To sign
Transactional email	Worker outbox → Resend, from support@playstake.org	Resend	PlayStake	
Marketing	Not carried out	—	—	No affiliates or ads
Website analytics	Google Analytics 4	Google	PlayStake	Public pages only, after consent
Error monitoring and alerting	Sentry; admin email alerts	Sentry	PlayStake	
Ledger audit and reconciliation	Worker (daily 03:00 UTC)	PlayStake	PlayStake	
Software development and release	GitHub → Railway deploy	GitHub, Railway	PlayStake	Tested in CI before release (Document 11)
Security testing	[PEN TEST PROVIDER]; annual security audit	[AUDITOR]	PlayStake	Not yet commissioned (Document 13)
Regulatory reporting	Email / eServices	—	Head of Compliance	Document 14

5. Changes

A change to any location, provider or operator in this map is assessed before it happens. Changes to where remote gambling equipment is located, and to key suppliers, are reported to the Commission as key events where LCCP 15.2.1 requires (Document 14).

Version	Date	Change
0.1	30 September 2026	First draft
0.2	27 October 2026	Region recorded; recorder service and R2; Didit; independent dispute review; funds-protection disclosure; analytics and Google Workspace

Document 11 — Testing Strategy

Operator	[COMPANY NAME], trading as PlayStake
Owner	[ENGINEERING LEAD NAME], with sign-off by [COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually; on any new game or match format, any change to how results are decided, or change to the RTS or testing requirements (Document 12)
Relates to	Remote gambling and software technical standards (RTS), and the Commission's testing strategy requirements for compliance with the RTS; licence condition on gambling software; Documents 12, 13

> Draft prepared from the platform as built on 30 September 2026. `[BRACKETS]` must be completed before submission. RTS paragraph numbers are for orientation and must be confirmed against the current RTS (Document 12). The split between third-party and in-house testing below must be confirmed with the Commission (§3.3).

1. Purpose

This strategy explains how PlayStake makes sure its gambling system meets the RTS before release and stays compliant through every change: what is tested, by whom, when, how it is recorded and who signs it off.

2. What we offer, and what needs testing

Product	Type	Random element	Outcome decided by
EA SPORTS FC 27 (refereed stream match)	Peer-to-peer, skill, external game	None in PlayStake	Independent human referee watching both players' Kick streams; win for either player or a draw; 15-minute dispute window
Tekken 8 (refereed stream match)	Peer-to-peer, skill, external game	None in PlayStake	Independent human referee watching both players' Kick streams; win for either player or a draw; 15-minute dispute window

PlayStake does not offer house-banked games; players stake against each other (£1 to £500) and PlayStake takes a disclosed fee of 5% of the pot, of which the referee receives 10%. PlayStake runs no game logic and no random number generation. The games are third-party titles that players run on their own devices (Document 08 §3.1).

> **Note for the application:** PlayStake's own on-site games, Tic-Tac-Toe and Darts 301, were withdrawn on 25 October 2026, together with their server-side game engines and the random number generator used for dart scatter. The other console titles previously listed were withdrawn at the same time. The game-session and game-event records of the withdrawn games are kept, append-only; no new ones are created.

> **Note for the application:** Higher / Lower, a card game that was almost entirely chance, was withdrawn on 30 September 2026 so that everything offered fits a betting intermediary licence. Its past match records are kept; no new match can be started.

3. Approach

3.1 Third-party testing (approved test house)

Until 25 October 2026 this section planned test-house certification of PlayStake's random number generator and Darts rules (RTS 7). Those games and the random number generator were withdrawn on that date, so there is no PlayStake game, game rule set or random number generator for a test house to certify.

Results are now decided by independent human referees. The integrity of results rests on referee independence, the hash-chained referee audit trail, dispute review and anomaly and collusion monitoring (Policy 01 §3.3), which are tested in-house (§3.2).

If PlayStake ever adds a game it runs itself, or any random element, a Commission-approved test house will test and certify it before release (§5). Whether the Commission expects any third-party testing of the platform functions in §3.2 is a point to confirm (§3.3). [CONFIRM with advisor]

3.2 In-house testing

PlayStake tests everything else itself, under this strategy, with results recorded:

Area	How we test it	RTS
Customer information: rules, fees, payouts shown before commitment	Manual review of the game guides (`/games/ea-sports-fc-27` , `/games/tekken-8`), Match Rules and Fair Play pages against the code at each release; screenshots kept	RTS 3
Safer gambling tools: deposit limits (gross, most restrictive applies), 24-hour delay on increases, first-deposit prompt, six-monthly review, breaks, reality checks, clock/elapsed time	Automated integration tests; manual check each release	RTS 12, 13, 14
Interrupted and abandoned matches	Automated tests: a match no referee claims within 10 minutes is cancelled and refunded; a stalled claim is released; a match running past 2 hours is cancelled and refunded; settlement of finished-but-unsettled matches	RTS 10
Collusion, cheating, bots	Controls reviewed each release; tests prove that a referee can't claim a match with a player they follow, are followed by or have a block with, that the referee audit chain detects altered, deleted or reordered events, and that a player can't stake against themselves	RTS 11, 16
Ledger and escrow integrity	Automated tests of `transfer()` , escrow netting to zero, conservation; database triggers make entries append-only; daily production audit	Licence conditions on customer funds; RTS security requirements
Eligibility gate: KYC, GAMSTOP, breaks, account status	Automated tests	RTS 12, 14
Customer funds disclosure: rating shown in writing; acknowledgement before deposit and before staking deposited funds; six-monthly reminder with balance; re-acknowledgement after a change	Automated integration tests; manual check of wording against Policy 19 each release	LCCP 4.2.1
Independent dispute review: reviewer conflicts, one reviewer per dispute, overturn tracking	Automated integration tests	RTS 11
Match recordings: recording page access, sealing into the audit trail, retention, who may watch	Automated integration tests; end-to-end recording test against live Kick streams before release (done 26 October 2026)	RTS 5/6, 11
Security controls	Document 13; independent penetration test; annual security audit	RTS security requirements

3.3 Points to confirm with the Commission

- Whether any RTS test requirement applies differently to peer-to-peer skill games where PlayStake is not a party to the bet.
- Whether a test house must also cover the platform functions listed in §3.2, or whether an in-house declaration is acceptable for them.

4. Automated testing on every change

- Every change goes through GitHub. CI runs lint, a type check, a dependency vulnerability audit (fails on critical findings), a malware scan and the full test suite against real PostgreSQL and Redis. A change can't be released unless CI passes.
- The suite (384 tests on 27 October 2026) includes, among others:
  - `tests/unit/ledger/` — double-entry transfers, escrow, audit invariants
  - `tests/integration/referee-lifecycle.test.ts` — one referee per match, conflict checks on follows and blocks, start only when live on Kick, cancellation sweeps for unclaimed and overlong matches
  - `tests/integration/referee-operations.test.ts`, `referee-code.test.ts`, `tests/unit/referees/audit.test.ts` — overturn tracking, Code of Conduct acceptance, hash-chained audit trail
  - `tests/integration/self-bet.test.ts`, `dual-source-result.test.ts` — no self-play; mismatched results open a dispute
  - `tests/integration/dispute-review.test.ts` — only an admin or approved reviewer with no link to the players decides a dispute; one reviewer at a time
  - `tests/integration/match-recording.test.ts` — recorder access tokens, sealing, 30-day and 12-month retention, holds during disputes, playback only for reviewers, viewing logged
  - `tests/integration/customer-interaction.test.ts` — includes the funds-protection disclosure, acknowledgement gates and six-monthly reminder
  - `tests/integration/compliance-gates.test.ts`, `limit-review.test.ts`, `session-idle.test.ts`, and the responsible-play, KYC, AML and complaints suites

5. Change control

Change class	Examples	Testing before release	Sign-off
Major	New game or match format; change to the standard settings or how results are decided; change to referee conflict checks, the referee audit trail or dispute handling; change to fee or settlement arithmetic	Full automated suite; update the game guides, Match Rules and Fair Play pages shown to customers; test-house testing before release if the change adds a PlayStake-run game or any random element (§3.1)	Engineering lead + Head of Compliance
Standard	Changes to safer-gambling tools, limits, eligibility, payments, ledger	Full automated suite plus new tests for the change; manual check of customer-facing text	Engineering lead + Head of Compliance
Minor	Copy, styling, non-gambling pages	Full automated suite	Engineering lead
Emergency	Security fix	Full automated suite; retrospective review within 5 working days	Engineering lead; Head of Compliance informed same day

Each release records: the commit, the CI run, the change class, any test-house reference, and sign-off. Game catalogue and referee software versions are identified by the git commit of `src/lib/games/` and `src/lib/referees/`.

6. Monitoring in production

- **Result integrity:** every referee action is in the hash-chained referee audit trail, which can be verified for any match. Overturned referee decisions are tracked per referee and reviewed. (The monthly dart-scatter check planned here is no longer needed: Darts was withdrawn on 25 October 2026.)
- **Ledger:** the ledger-audit worker verifies every account, every transaction and system-wide conservation daily and alerts on any failure.
- **Results:** the anomaly worker flags skewed win rates, single-winner patterns, fast settlements and volume spikes.

7. Annual security audit

The RTS security requirements call for an independent annual security audit against the ISO/IEC 27001:2022 controls listed in Document 13. For a new licensee the first audit is due within **six months of the licence being granted**, then each year. The auditor must be independent and suitably qualified (for example ISO/IEC 27001 Lead Auditor, CISA, CISM or CISSP). The report goes to the Commission at securityaudit@gamblingcommission.gov.uk. Auditor: [AUDITOR]. First audit due: [GRANT DATE + 6 MONTHS].

8. Records

Any test-house reports, CI results, release sign-offs and security audit reports are kept for at least five years.

Version	Date	Change
0.1	30 September 2026	First draft
0.1	25 October 2026	On-site games (Tic-Tac-Toe, Darts 301) and their random number generator withdrawn; catalogue reduced to EA SPORTS FC 27 and Tekken 8, both refereed stream matches; test-house scope, change control and monitoring updated to match

Document 12 — RTS Compliance Statement and Change Register

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Monthly check of the Commission's RTS pages; full review annually
Relates to	Remote gambling and software technical standards (RTS); Documents 11, 13

> Draft prepared from the platform as built on 30 September 2026. RTS references are for orientation and must be confirmed against the Commission's current published text before submission. Items marked **confirm** depend on the Commission's view of which requirements apply to peer-to-peer play.

1. Purpose

This document states how PlayStake meets each RTS requirement that applies to it, and keeps a register of changes to the RTS so that none is missed. Testing of these controls is covered in Document 11; the RTS security requirements in Document 13.

2. How we track RTS changes

- The Head of Compliance checks the Commission's RTS pages, news and consultation responses **monthly** and records the check in §5, even when nothing has changed.
- Each change is entered in the register (§4) with its effective date, what it means for PlayStake, the work needed, an owner and a target date at least one month before it takes effect.
- Work is delivered through the change control in Document 11 §5 and the register is updated with the release and evidence.
- We also subscribe to the Commission's email updates and review industry updates from our compliance adviser.

3. Compliance statement

Topic	RTS ref (confirm)	Applies?	How PlayStake meets it	Evidence
Rules, game descriptions and likelihood of winning	RTS 3	Yes	Each game's guide page shows the standard settings, how the referee decides the result, draw and disconnect rules, stakes and payouts; the Match Rules apply to every match; the Fair Play page summarises both games	`src/lib/games/guides.ts`, `/games/ea-sports-fc-27`, `/games/tekken-8`, `/match-rules`, `/fair-play`

Topic	RTS ref (confirm)	Applies?	How PlayStake meets it	Evidence
Fees and what a customer can win	RTS 3 / LCCP	Yes	Fee %, fee amount, win payout and draw return shown on the stake screen and every challenge before commitment, using the same arithmetic as settlement	`src/components/lobby/PayoutSummary.tsx`, `src/lib/utils/payout.ts`
Display of results and records	RTS 5 / 6	Yes	Referee's result and written notes shown to both players; bet history and bet detail pages; append-only, hash-chained referee audit trail that can be verified for any match	`src/lib/referees/audit.ts`
Generation of random outcomes	RTS 7	**No** (since 25 October 2026)	PlayStake has no game with a random outcome. Darts 301 and its random number generator were withdrawn on 25 October 2026. Results of refereed matches are decided by human referees, not by PlayStake software.	Document 11 §3.1; register §4
Interrupted and abandoned gambling	RTS 10	Yes	After a drop the referee decides from both streams whether to carry on, replay the affected part or award the match; a player not back within 10 minutes may lose the match. A match no referee takes within 10 minutes, or not finished within 2 hours of starting, is cancelled with both stakes returned in full. Our faults are reviewed and voided or corrected. Published on `/fair-play` and `/match-rules`.	`src/workers/bet-expiry.worker.ts`, `src/lib/referees/service.ts`; tests
Anti-collusion and cheating; recovered funds policy	RTS 11	Yes	Results decided by independent referees, who can't officiate their own match or players they follow, are followed by or have a block with; hash-chained referee audit trail; anomaly and shared-identity detection; cheating, collusion and bots prohibited; published policy on suspending accounts, voiding matches, returning stakes to affected players and informing them	`/fair-play` §§5–6; Policy 01
Financial limits	RTS 12	Yes	See §3.1	

Topic	RTS ref (confirm)	Applies?	How PlayStake meets it	Evidence
Time: clock or elapsed time; reality checks	RTS 13	Yes	The current time and the session's elapsed time are always on screen while signed in: in the header on larger screens, at the top of every page on phones. Optional reality checks at a customer-chosen interval show time, stakes and net result, across the dashboard. Matches are played in the customer's own game, outside PlayStake. [CONFIRM with advisor whether this placement is sufficient]	`SessionClock.tsx` (header and dashboard layout); `SessionReminder.tsx`
Breaks in play and self-exclusion	RTS 14 (updated 12 Jan 2026 — **review changes**)	Yes	Cool-off and self-exclusion breaks that can't be shortened; withdrawal still allowed; return from self-exclusion needs a request and a 24-hour cooling-off; GAMSTOP (planned)	Policies 03, 04
Third-party software and bots	RTS 16	Yes	Bots, scripts and software that plays for a player prohibited in terms, Match Rules and Fair Play; the referee watches both players' streams; detection by referee observation and pattern review	`/fair-play` §5, `/match-rules`
Auto-play, game speed, near-miss and similar slot/casino design rules	Various	**Confirm** — likely not applicable to peer-to-peer skill games	PlayStake runs no game of its own; no auto-play or spin-style features on the platform	—
Security requirements	RTS security section (ISO/IEC 27001:2022 Annex A; audits against the 2013 version ended 31 October 2024)	Yes	Document 13	Document 13
Protection of customer funds (LCCP, not RTS)	LCCP 4.1.1, 4.2.1	Yes	Rating "not protected – no segregation" in the Terms; written disclosure acknowledged before deposit and before staking deposited funds; six-monthly reminder with balance; re-acknowledged after any change	Policy 19; `src/lib/compliance/funds-protection.ts`

3.1 RTS 12 financial limits

Requirement	Effective	Status
Prompt to set a deposit limit at registration or before first deposit, with limit-setting presented as the default	31 October 2025	**Met.** First deposit is blocked until the customer sets a limit or actively declines; the answer is recorded. **Check** that setting a limit is the visually primary option in the prompt.
Remind customers at least every six months to review their limits	31 October 2025	**Met** (built 30 September 2026). Six-monthly reminder in the dashboard (`/play` was removed on 25 October 2026); answering, or changing a limit, restarts the period.
Increases to limits take effect only after a cooling-off period of at least 24 hours; decreases immediately	31 October 2025	**Met.** Increases and removals are staged for 24 hours.
Gross deposit limits must be offered as a minimum	**30 September 2026** (postponed from 30 June 2026)	**Met.** Limits count all deposits, pending and completed, without netting off withdrawals.
Only a gross deposit limit may be called a "deposit limit"; other limit types must be named accurately	30 September 2026	**Met.** The only financial limit offered is a gross deposit limit.
Where limits over several timeframes are set, the most restrictive applies	30 September 2026	**Met.** Every daily, weekly and monthly limit is checked on each deposit; the first one breached blocks it.
Definitions of stake, loss and net-deposit limits; equal prominence of limit types	30 September 2026	**Not applicable today** — no stake, loss or net-deposit limits are offered. If any is added, it must follow the definitions and be given equal prominence.

4. RTS change register

Date published	Change	Effective	Impact on PlayStake	Action	Owner	Status
31 Oct 2025	RTS index updated; RTS 12 financial limits changes (phase 1)	31 Oct 2025	First-deposit limit prompt, six-monthly review, 24-hour increase delay	Built; six-monthly reminder added 30 Sep 2026	Head of Compliance	Done
[DATE]	RTS 12 phase 2: gross deposit limits, naming, most restrictive timeframe, definitions, equal prominence	Originally 30 Jun 2026, **postponed to 30 Sep 2026**	Deposit limits already gross and all timeframes enforced	Confirmed compliant 30 Sep 2026 (§3.1)	Head of Compliance	Done
12 Jan 2026	RTS 14 updated	[CONFIRM]	Breaks and self-exclusion tools	Review the updated text against Policies 03 and 04 and record the outcome	Head of Compliance	**Open**
29 Jan 2026	Consultation response on gaming machine technical standards (GMTS)	[N/A]	None: PlayStake offers no gaming machines. This was not an RTS change.	None	Head of Compliance	Closed
[DATE]	RTS security requirements move to ISO/IEC 27001:2022 control references	[CONFIRM]	Security control mapping	Document 13 maps to the 2022 controls	Head of Compliance	Done

Date published	Change	Effective	Impact on PlayStake	Action	Owner	Status
26 Oct 2026	PlayStake product change (not an RTS change): independent dispute review; every refereed match recorded by PlayStake	26–27 Oct 2026	Strengthens RTS 5/6 (records) and RTS 11 (cheating and collusion): recordings sealed into the audit trail; disputes decided by someone independent of the match	Documents 01, 08–11, 18 updated	Head of Compliance	Closed
27 Oct 2026	LCCP 4.2.1 disclosure built (not an RTS change)	27 Oct 2026	Funds-protection rating disclosed, acknowledged and re-acknowledged every six months	Policy 19	Head of Compliance	Closed
25 Oct 2026	PlayStake product change (not an RTS change): on-site games (Tic-Tac-Toe, Darts 301) and their random number generator withdrawn; catalogue reduced to EA SPORTS FC 27 and Tekken 8, both refereed stream matches	25 Oct 2026	RTS 7 no longer applies; test-house RNG and game certification no longer needed; RTS 3, 5/6, 10, 11, 13 and 16 now met through game guides, Match Rules and refereeing; the on-screen clock moved from `/play` to the header and every dashboard page (RTS 13)	Compliance statement (§3) and Document 11 updated; clock re-homed 25 Oct 2026	Head of Compliance	Closed

5. Monthly check log

Month	Checked by	RTS pages changed?	Register updated?
September 2026	[NAME]	See register	Yes
October 2026	[NAME] (checked 27 Oct 2026)	No: the RTS page was last updated 31 October 2025 (RTS 12). The RTS 12 changes originally due 30 June 2026 took effect 30 September 2026. RTS 14 update of 12 January 2026 still to review (register).	Yes

Version	Date	Change
0.1	30 September 2026	First draft
0.1	25 October 2026	On-site games and their random number generator withdrawn; catalogue reduced to EA SPORTS FC 27 and Tekken 8; compliance statement and change register updated

Document 13 — Information Security Policy (RTS security requirements)

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance, as Information Security Officer until a dedicated role is appointed; [ENGINEERING LEAD NAME] for technical controls
Version	0.1 — draft for licence application
Review	Annually; after any security incident; after the annual security audit
Relates to	RTS security requirements (ISO/IEC 27001:2022 controls named by the Commission); LCCP 15.2.1 key events; UK GDPR; Documents 08, 11, 14

> Draft prepared from the platform as built on 30 September 2026. Status reflects what exists in the code and configuration today. "Partial" and "Planned" items are listed in §6 with owners. `[BRACKETS]` must be completed before submission.

1. Policy statement

PlayStake protects customer funds, customer data and the integrity of its games. We base our information security management on ISO/IEC 27001:2022 and meet, as a minimum, the controls the Commission's RTS security requirements name. The controls apply to every system that handles customer data, money or game outcomes: the web and worker services, the database, the admin console, and the suppliers in Document 08.

We commit to:

- a named owner for information security with authority to stop a release or suspend a service;
- controls proportionate to risk, reviewed at least annually;
- an independent security audit every year, the first within six months of licence grant (Document 11 §7);
- reporting security incidents to the Commission and the ICO when required (Document 14).

2. Scope

In scope	Notes
Web, worker and recorder services, PostgreSQL, Redis (Railway, EU West, Netherlands)	All customer data, the ledger and match records
Match-recording storage (Cloudflare R2, EU)	Private bucket; bucket-scoped key for object read/write only; playback by 15-minute signed links; every viewing logged
Admin console and staff accounts	Privileged access
Source code, CI and deployment pipeline (GitHub → Railway)	Integrity of released software
Suppliers handling customer data (Stripe, Resend, Sentry, GAMSTOP, IBAS, Didit, Cloudflare, Google)	Through supplier management (5.19–5.23)
Staff devices used for administration	Endpoint controls (8.1)

3. Key technical safeguards

- **Money:** double-entry ledger; only `transfer()` changes balances; sufficient-funds check in the same SQL statement as the debit; idempotency keys; ledger entries append-only by database trigger; daily automated audit of every account and transaction.
- **Results:** PlayStake runs no games and no random number generation (withdrawn 25 October 2026). Results are recorded by independent referees through the referee console into a hash-chained, append-only audit trail; every match is recorded and the file's SHA-256 sealed into that trail; disputes are decided by someone independent of the match.
- **Identity and access:** passwords hashed with bcrypt (cost 12); sign-in rate limits and lockout; session tokens random, stored only as SHA-256 hashes, 7-day lifetime and 30-minute idle timeout; staff require TOTP two-factor authentication (enforced in production); role-based access checked on every admin route.
- **Data protection:** identity documents encrypted with AES-256-GCM; Kick OAuth tokens encrypted under a separate key; card data never touches PlayStake (Stripe Elements); all traffic over HTTPS with HSTS.
- **Web application:** input validation (Zod) on all API routes; Content-Security-Policy; framing blocked except for the embeddable widget; `nosniff`, strict referrer policy, restrictive permissions policy; identity-document responses sandboxed and never cached.
- **Integrations:** Stripe and Kick webhooks verified by signature; outbound webhooks to developers signed with HMAC-SHA256; constant-time comparison of secrets.
- **Audit:** every privileged staff action (including each view of an identity document) is written to an append-only admin audit log with actor, target, change and IP address.

4. Control mapping — ISO/IEC 27001:2022

Status: **In place** — implemented and evidenced; **Partial** — some of the control exists, gap in §6; **Planned** — not yet in place.

4.1 Organisational controls

Control	How PlayStake meets it	Status
5.1 Policies for information security	This policy, approved by the board and reviewed annually	Partial — board approval pending
5.10 Acceptable use of information and assets	Staff acceptable-use rules: admin console only from managed devices, no customer data in personal tools, no sharing of accounts	Planned — write and sign
5.15 Access control	Roles (PLAYER, DEVELOPER, ADMIN, plus approved referee status) enforced server-side on every route; least privilege for staff	In place
5.16 Identity management	One named account per person; no shared admin accounts; accounts closed on leaving	In place (process)
5.17 Authentication information	bcrypt password hashing; TOTP 2FA for staff; secrets only in Railway environment variables, never in code	In place
5.18 Access rights	Staff access granted by the Head of Compliance, recorded, and reviewed quarterly; infrastructure (Railway, GitHub, Stripe) access reviewed at the same time	Partial — first review to schedule
5.19 Information security in supplier relationships	Suppliers assessed before use (Document 08 §4)	Partial — assurance reports to collect
5.20 Addressing security within supplier agreements	DPAs and security terms in each supplier contract	Partial — confirm DPAs on file
5.21 Managing security in the ICT supply chain	Dependabot updates; CI dependency audit fails on critical vulnerabilities; malware scan on every push and weekly; lockfile-pinned installs (`npm ci`)	In place

Control	How PlayStake meets it	Status
5.22 Monitoring and review of supplier services	Annual supplier review; incident notifications from suppliers assessed under Document 14	Planned
5.23 Information security for use of cloud services	Railway project access limited to named staff with 2FA; region and backups recorded	Partial — region, backups (§6)
5.24 Incident management planning and preparation	Document 14	In place (document)
5.25 Assessment and decision on information security events	Triage in Document 14 §3	In place (document)
5.26 Response to information security incidents	Document 14 §4	In place (document)
5.28 Collection of evidence	Append-only audit logs, ledger, hash-chained referee audit trail and historical game records; log export and preservation steps in Document 14	Partial — log retention (§6)
5.35 Independent review of information security	Annual independent security audit; quarterly review by external compliance adviser	Planned

4.2 People controls

Control	How PlayStake meets it	Status
6.3 Awareness, education and training	Security training on joining and annually, recorded with safer-gambling and AML training (Master Manual §5.4)	Planned
6.5 Responsibilities after termination or change of employment	Leaver checklist: close admin account, remove Railway/GitHub/Stripe access, rotate any shared secrets the person could see	Planned — write checklist
6.7 Remote working	Administration only from managed devices with disk encryption and screen lock, over HTTPS with 2FA	Partial — device standard to document
6.8 Information security event reporting	Anyone who spots a possible incident reports it at once to the Information Security Officer (Document 14 §2)	In place (document)

4.3 Physical controls

PlayStake operates no data centre or office servers; physical security of hosting is provided by Railway and its infrastructure providers.

Control	How PlayStake meets it	Status
7.8 Equipment siting and protection	Hosting provider's data-centre controls, evidenced by its assurance report	Partial — report to collect
7.10 Storage media	No customer data on removable media; exports only when necessary, encrypted, and deleted after use	Planned — write rule
7.14 Secure disposal or re-use of equipment	Staff devices wiped before disposal or re-use; provider handles hosting media	Planned — write rule

4.4 Technological controls

Control	How PlayStake meets it	Status
8.1 User endpoint devices	Staff devices: full-disk encryption, OS updates, screen lock, password manager	Partial — to document and check
8.2 Privileged access rights	ADMIN role limited to named staff; 2FA enforced; all admin actions audit-logged; production database access limited to named engineers through Railway	In place

Control	How PlayStake meets it	Status
8.3 Information access restriction	Customers see only their own data; bet and game data limited to participants; identity documents only to admins, streamed decrypted per request and logged	In place
8.5 Secure authentication	Rate-limited sign-in and lockout; session tokens hashed; 30-minute idle timeout; 7-day absolute lifetime; staff 2FA	In place
8.7 Protection against malware	CI malware scan; dependency audit; no file execution from uploads; identity documents served sandboxed with `nosniff`; removed a disguised HTML file from public assets (30 Sep 2026)	In place
8.13 Information backup	Railway PostgreSQL backups	**Planned — confirm enabled, set retention, test a restore**
8.15 Logging	Structured JSON logs from web and worker; admin audit log; ledger and game event logs; Sentry error reports	Partial — log retention period and access to be set
8.17 Clock synchronisation	Hosts synchronised by the provider; the application records times in UTC	Partial — database columns store times without time zone (UTC by convention); migrate to `timestamptz`
8.18 Use of privileged utility programs	Direct database access (Prisma Studio, psql) only for named engineers, for a recorded reason; money never changed outside `transfer()`	Partial — record usage
8.20 Networks security	Database and Redis reachable only on Railway's private network [CONFIRM no public database proxy]; all public traffic over HTTPS	Partial — confirm
8.21 Security of network services	TLS on all endpoints; HSTS; webhook signatures	In place
8.22 Segregation of networks	Production separate from development and CI; services communicate over Railway's private network	Partial — confirm
8.24 Use of cryptography	AES-256-GCM for identity documents and OAuth tokens with separate keys; bcrypt; SHA-256 token hashes; HMAC-SHA256 webhook signing; TLS. Keys held only in the hosting environment; key rotation procedure to write	Partial — rotation procedure
8.25 Secure development life cycle	All changes in Git; CI lint, type check, tests, dependency audit and malware scan before release; change classes and sign-off (Document 11 §5)	In place
8.26 Application security requirements	Server-side authorisation on every route; identity from session only, never the request body; input validation; idempotency on money routes	In place
8.27 Secure system architecture and engineering principles	Ledger as trust boundary; results recorded only by approved referees with a hash-chained audit trail; append-only records; fail-closed eligibility gate	In place
8.29 Security testing in development and acceptance	Automated tests for authorisation and exploit paths (e.g. forged sessions, client-declared results); independent penetration test before launch and annually	Partial — penetration test not yet done
8.30 Outsourced development	None at present; any future outsourced development under the same CI and review	In place
8.31 Separation of development, test and production environments	Local and CI environments use their own databases; production secrets never in development	In place
8.32 Change management	Document 11 §5	In place

Control	How PlayStake meets it	Status
8.33 Test information	Tests create their own synthetic data; production data is never copied into test	In place

5. Known residual risks (accepted, with review date)

Risk	Why accepted for now	Review
High-severity advisories in the Prisma CLI toolchain (`@prisma/dev`, `mysql2`, `deepmerge-ts`, `find-my-way`)	Development/migration tooling, not used to serve requests; the only fix offered is a major-version downgrade. Tracked by Dependabot.	Monthly
Content-Security-Policy allows inline scripts	Needed by the Next.js runtime; move to per-request nonces	Before launch
Rate limits held in each web process's memory	Correct with one web instance; must move to Redis before scaling out	Before running two web instances

6. Gaps and actions

#	Action	Control	Owner	Due
1	Confirm Railway backups are enabled, set retention, and test a restore; record the result	8.13	Engineering	Before launch
2	Set log retention and access; export logs to durable storage	8.15, 5.28	Engineering	Before launch
3	Commission an independent penetration test and fix findings	8.29	Head of Compliance	Before launch
4	Appoint the annual security auditor; first audit within 6 months of grant	5.35	Head of Compliance	Grant + 6 months
5	Write acceptable use, leaver checklist, device standard, media and disposal rules; staff sign them	5.10, 6.5, 6.7, 7.10, 7.14, 8.1	Head of Compliance	Application
6	Collect supplier assurance reports and DPAs	5.19–5.23, 7.8	Head of Compliance	Application
7	Migrate timestamp columns to `timestamptz`	8.17	Engineering	Within 3 months
8	Key rotation procedure for encryption and signing keys	8.24	Engineering	Before launch
9	Move rate limiting to Redis	8.5	Engineering	Before scaling
10	Nonce-based CSP	8.26	Engineering	Before launch
11	Confirm database and Redis are not publicly reachable	8.20, 8.22	Engineering	Application
12	Quarterly access review of admin, Railway, GitHub and Stripe accounts	5.18	Head of Compliance	Quarterly from launch

Version	Date	Change
0.1	30 September 2026	First draft
0.2	27 October 2026	Recorder service and R2 in scope; results section updated after the on-site games were withdrawn

Document 14 — Incident Response and Key Event Reporting

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance and Information Security Officer
Version	0.1 — draft for licence application
Review	Annually; after every Severity 1 or 2 incident; after a test exercise
Relates to	LCCP 15.2.1 (reporting key events); LCCP 15.2.2 (other reportable events); RTS security requirements (ISO/IEC 27001:2022 5.24–5.28, 6.8); UK GDPR Articles 33–34; Proceeds of Crime Act 2002; Document 13

> Draft prepared from the platform as built on 30 September 2026. The key event list in §6 must be checked against the current LCCP before submission. `[BRACKETS]` must be completed.

1. Purpose

This procedure sets out how PlayStake spots, handles, records and reports incidents that threaten customer funds, customer data, game fairness or the availability of the service, and how we meet our duty to report key events to the Gambling Commission.

2. Reporting an incident

Anyone — staff, a referee, a supplier or a customer — who sees something that may be an incident reports it straight away to the Information Security Officer (ISO): [PHONE], [EMAIL], and in the operations channel. Customers report through support@playstake.org or the complaints form; support passes anything security-related to the ISO at once. Don't investigate alone, delete anything, or contact a suspected attacker.

Automatic triggers:

- ledger-audit worker failure (a balance or transaction that doesn't reconcile) — email alert to `EMAIL_ADMIN`;
- worker heartbeat missing (`/api/health` reports the worker down);
- error spikes in Sentry;
- anomaly, AML or player-risk alerts;
- supplier incident notices (Stripe, Railway, Resend, Kick, GAMSTOP).

3. Triage

The ISO decides severity within 1 hour of the report and records it in the incident register (§8).

Severity	Examples	Response
1 — Critical	Customer funds wrong or at risk; ledger doesn't reconcile; confirmed data breach; unauthorised admin access; a game deciding results wrongly; service unavailable to customers for more than 1 hour	Incident lead appointed at once; board informed within 4 hours; work continues until contained
2 — High	Suspected breach under investigation; fault affecting some customers' bets or limits; safer-gambling tool not working (limits, breaks, GAMSTOP check); supplier outage stopping deposits or withdrawals	Incident lead appointed same day; board informed within 24 hours
3 — Medium	Degraded performance; isolated bug with no money or data impact; blocked attack attempt	Handled in normal work; reviewed weekly

Severity	Examples	Response
4 — Low	Near miss; policy breach without impact	Logged; reviewed monthly

A fault in a safer-gambling control is always at least Severity 2, and gambling for affected customers is stopped until it's fixed.

4. Response steps

1. **Contain.** Stop the harm first. Options, in order of preference:
   - suspend affected accounts (`/admin/users`);
   - turn off the affected feature or game (pause a game at once by switching it off in the database, `games.is_active = false`, which stops new challenges and declarations without a deploy; disable deposits by removing the payments flag);
   - stop the worker service if it is moving money wrongly;
   - put the web service into maintenance, or scale it to zero, in Railway;
   - rotate compromised secrets (Railway environment variables) and sign all users out (delete sessions).
2. **Preserve evidence.** Don't change or delete records. The ledger, referee audit trail and admin audit log are append-only. Export relevant application logs from Railway and Sentry before they age out; take a database snapshot; record every action taken, with times, in the incident record.
3. **Assess.** Which customers, how much money, what data, since when, and how. Use the ledger audit, referee audit trail and admin audit log to establish the facts.
4. **Fix and recover.** Deploy the fix through CI (emergency change class, Document 11 §5). Restore from backup only if needed and only after preserving evidence. Correct any wrong payment with a new, reversing ledger transfer — never by editing records.
5. **Tell the people who need to know** (§5 and §6).
6. **Close and learn.** Within 10 working days of containment, a post-incident review records the cause, the impact, what worked, what didn't, and actions with owners. Policies, controls and tests are updated.

5. Notifying customers and others

Who	When	How
Affected customers	When their money, bets or data are affected. For a personal data breach likely to cause high risk, without undue delay (UK GDPR Art. 34).	Email and in-app message: what happened, what it means for them, what we've done, what they should do
Information Commissioner's Office	Personal data breach likely to risk people's rights and freedoms: **within 72 hours** of becoming aware (UK GDPR Art. 33)	ICO breach reporting service
Stripe	Suspected compromise of payment flows or Stripe credentials	Stripe support; rotate keys
National Crime Agency	Suspected money laundering or terrorist financing	Suspicious Activity Report by the MLRO (Policy 07)
Police / Action Fraud	Suspected crime, e.g. fraud or unauthorised access	Report online; record reference
Suppliers	Incident involving their service	Supplier's incident route
IBAS	Only as part of a customer's complaint	—

6. Key events: reporting to the Gambling Commission

LCCP 15.2.1 requires the Commission to be told of key events **as soon as reasonably practicable and in any event within five working days** of PlayStake becoming aware of them. Reports are made through the Commission's eServices portal by the Head of Compliance, who keeps a copy with the incident record.

Key events most relevant to PlayStake (check the full list in the current LCCP):

Key event	Example for PlayStake
A breach of information security that affects the confidentiality of customer data, or that stops customers accessing the gambling system for **more than 12 hours**	Leak of KYC documents; database exposed; outage over 12 hours
A fault in gambling software or systems that causes wrong payouts or losses to customers	Game deciding a wrong winner; settlement paying the wrong amount; limit not applied
Any change to where remote gambling equipment is located, or to the gambling software used	Moving Railway region or provider (Documents 08, 10)
Appointment or loss of key suppliers or significant changes to outsourcing	Change of payment provider or hosting
Criminal investigation or proceedings, or regulatory action elsewhere, involving PlayStake or its key people	—
Material financial events (e.g. insolvency, breach of banking covenants, significant loss)	—
Changes to key people, ownership or control	Change of Head of Compliance / MLRO
Suspected cheating or match-fixing involving customers that has led to action	Collusion ring found and accounts closed

Other events under LCCP 15.2.2 (for example suspicion of offences, or information that may be relevant to the Commission) are reported as that condition requires.

What each report contains: what happened and when; when we became aware; customers, money and data affected; what we've done to contain and fix it; customer communications; further actions and dates; contact person.

7. Playbooks

Incident	First actions
Ledger audit fails	Stop the worker; identify the transaction(s); compare `balance` with the entry sum; no manual balance edits; correct with reversing transfers after sign-off; Severity 1
Wrong result recorded (referee error or misconduct, or a platform fault)	Suspend the referee if misconduct is suspected; list affected matches from the referee audit trail; void or correct with reversing transfers; tell affected customers; key event if payouts were wrong; fix and test before re-enabling (Document 11 §5)
Leaked secret (API key, encryption key, database URL)	Rotate in Railway; redeploy; delete all sessions; review audit and access logs for use; for the KYC key, re-encrypt documents under a new key
Unauthorised admin access	Suspend the admin account; delete its sessions; review the admin audit log for every action; reverse unauthorised changes; reset 2FA
Outage	Check Railway status and `/api/health`; communicate on the site; if customers can't access the system for more than 12 hours, report as a key event
Safer-gambling tool failure	Stop gambling for affected customers (suspend or pause the feature); fix; review whether anyone gambled who shouldn't have and refund where appropriate
Supplier breach (e.g. Resend, Sentry)	Get facts from the supplier; assess what PlayStake data was involved; follow §5 and §6

8. Incident register

Every incident, including near misses, is recorded: reference, date and time reported, reporter, severity, description, customers/money/data affected, actions and times, notifications made (with references and times), root cause, lessons and actions, date closed. Kept for at least five years and reviewed at each quarterly compliance meeting.

9. Testing this procedure

A tabletop exercise is run at least annually (for example, a simulated KYC data leak and a simulated wrong-payout game fault), recorded, and used to update this document.

Version	Date	Change
0.1	30 September 2026	First draft

Document 15 — UAE (GCGRA) Technical Standards and Certification Plan

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance, with [ENGINEERING LEAD NAME]
Version	0.1 — planning draft
Review	Before any UAE engagement; on any GCGRA publication
Relates to	UAE General Commercial Gaming Regulatory Authority (GCGRA) requirements; GLI standards series; Documents 11, 12, 13

> **Planning draft, not verified against primary sources.** The GCGRA website could not be accessed when this was prepared. Everything below about GCGRA requirements, licence categories, approved standards and approved laboratories comes from public secondary reporting and must be confirmed directly with the GCGRA and UAE legal counsel before any decision is taken. Gambling is otherwise prohibited in the UAE; nothing may be offered to UAE residents until PlayStake (or a partner) is licensed by the GCGRA.

1. Purpose

To set out what PlayStake would need to do to have its gambling system assessed and certified for the UAE market, reusing as much as possible of the UK work in Documents 11–13.

2. What we understand today (to confirm)

Topic	Current understanding	Source status
Regulator	GCGRA, a federal authority set up in 2023 to license and regulate commercial gaming in the UAE	Secondary reporting
Online gambling	The GCGRA licenses internet gaming and sports wagering; the first such licence was reported in November 2025 (Play 971)	Secondary reporting
Peer-to-peer skill wagering	**Unknown** whether a licence category exists for a platform like PlayStake, or whether it must operate through, or supply, an existing licensee	To ask GCGRA
Technical standards	GCGRA technical standards are reported to be based on the GLI standards series, in particular **GLI-19** (Interactive Gaming Systems) and **GLI-33** (Event Wagering Systems), with GCGRA-specific requirements on top	Secondary reporting
Independent test laboratories	Reported as Gaming Laboratories International (GLI) and BMM Testlabs (BMM North America and BMM Spain)	Secondary reporting
Data location, currency, identity	Not yet known. Likely requirements to check: hosting or data residency in the UAE, AED accounts, UAE identity verification (e.g. Emirates ID / UAE Pass), UAE-only geolocation	To ask GCGRA

3. Which standards are likely to apply

Standard	Why it may apply	Main areas it covers
GLI-19 Interactive Gaming Systems	PlayStake is an online platform with player accounts and a wallet	Player account management, KYC and geolocation, wallet and financial transactions, responsible gaming tools, interrupted matches, logging and reporting, security and change management. Its game fairness and RNG sections are unlikely to apply: PlayStake has run no games of its own since 25 October 2026 [CONFIRM with advisor]
GLI-33 Event Wagering Systems	Stream matches are wagers on the outcome of an external event (a live game), settled on a referee's result	Wager acceptance, event and result management, settlement, voids and cancellations
GCGRA-specific requirements	Local rules on responsible gaming, AML, data and reporting	[TO OBTAIN]

4. Plan

Phase	What	Output	Indicative timing
1. Confirm the route	Legal counsel in the UAE; formal enquiry to the GCGRA on whether and how peer-to-peer skill wagering can be licensed; whether PlayStake would apply itself or supply a licensee (B2B)	Written answer and chosen route	Month 1–2
2. Obtain the rules	Get the GCGRA technical standards, licensing rules and any lab-submission guidance; confirm which GLI standards and versions apply	Requirements library	Month 2
3. Gap assessment	Map each requirement to the platform, reusing the UK RTS statement (Document 12), testing strategy (Document 11) and ISO 27001 mapping (Document 13). Early candidates: UAE geolocation; UAE identity checks; AED currency; data residency; GCGRA reporting feeds; game recall display; any limits or tools the GCGRA mandates	Gap register with owners	Month 3
4. Build	Close the gaps as a UAE configuration of the same platform, behind jurisdiction settings, through the change control in Document 11 §5	Release candidate	Months 4–6
5. Lab engagement	Engage GLI or BMM (as approved by the GCGRA). Pre-submission meeting; submit source code, documentation and a test environment; platform (GLI-19 / GLI-33) testing	Lab report and certificate	Months 6–9
6. Licence submission	Submit certificates with the licence application or the partner's change notification	Approval	After phase 5
7. Ongoing	Re-certification for changes as the GCGRA requires; keep one change register covering UK and UAE; annual security audit covering both	Maintained certification	Continuous

5. What carries over from the UK work

- **Refereed results** (`src/lib/referees/`): referee independence checks, a hash-chained, append-only audit trail and a dispute window — relevant to GLI-33 result management and settlement. (PlayStake's own games and their RNG were withdrawn on 25 October 2026, so there is no game or RNG to certify.)
- **Double-entry ledger and per-bet escrow**, append-only, audited daily — the core of wallet and financial transaction requirements.
- **Safer gambling tools** (deposit limits, breaks, reality checks, interactions) and the single eligibility gate.
- **Security controls** mapped to ISO/IEC 27001:2022 (Document 13), and the incident process (Document 14).
- **Test evidence:** the automated test suite and any UK test-house or security audit reports. Ask the lab whether any UK work can be reused to shorten the UAE assessment.

6. Decisions and risks

Item	Note
Licence route	The biggest uncertainty; everything else depends on it
Data residency	If UAE hosting is required, PlayStake needs a second deployment in a UAE region, not just configuration. This changes Documents 08–10.
Choice of lab	Choosing the same lab for the UK and UAE (GLI or BMM are on both lists) may reduce cost and time

7. Next actions

1. Instruct UAE counsel and send the GCGRA enquiry. Owner: Head of Compliance.
2. Ask GLI and BMM for a scoping call covering both UK RTS testing and UAE certification. Owner: Head of Compliance.
3. Obtain the current GLI-19 and GLI-33 standards and start the gap register. Owner: Engineering.

Version	Date	Change
0.1	30 September 2026	First draft

Policy 16 — Payment Services and Payment Methods

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance
Version	0.1 — draft for licence application
Review	Annually; before adding any payment method or provider; on any change to a provider's authorisation
Relates to	Gambling Commission requirement (in force 31 January 2024) that payments involving payment services are accepted only through a payment service provider as defined in the Payment Services Regulations 2017 (PSRs) — LCCP paragraph to be confirmed; LCCP 15.2.1 key events (change of key supplier); Documents 08, 13

> Draft prepared from the platform as built on 30 September 2026. `[BRACKETS]` must be completed, and each provider's authorisation checked on the FCA Financial Services Register, before submission.

1. Requirement

Where a payment to or from a customer involves a payment service, PlayStake may only accept or make it through a payment service provider (PSP) as defined in the PSRs: for example a bank, an authorised payment institution or an authorised electronic money institution. PlayStake does not provide payment services itself and does not accept payments in any other way. How customer balances are held, and what customers are told about their protection on insolvency, is in Policy 19.

2. How customers can pay us and be paid

Direction	Method	Provider	How it works
Deposit	Card (including Apple Pay and Google Pay, which are card payments)	Stripe	Card details are entered in Stripe's own payment form; Stripe processes the payment and tells PlayStake by signed webhook
Withdrawal	Payout to the customer's own bank account	Stripe (Connect Express)	The customer completes Stripe's onboarding once; PlayStake instructs Stripe to pay out

PlayStake does **not** accept cash, cheques, vouchers, cryptocurrency, direct bank transfers into its own account, payments from third parties, or any method not listed above.

3. Payment service provider register

Provider	Role	Authorisation	Status
Stripe Payments UK Ltd	Card acquiring and payouts for UK customers	FCA-authorised electronic money institution, FRN [900461 — confirm on the FCA register]	Integrated; running in **test mode**
Stripe Payments Europe Ltd	Card acquiring for EEA customers, if ever served	Authorised by the Central Bank of Ireland	Not used for UK customers
[ANY FUTURE PSP]			

Stripe and gambling. Stripe treats gambling as a restricted business that needs its prior written approval. Live processing must not start until Stripe has approved PlayStake's model in writing. If it does not, a PSP that supports licensed gambling must be appointed through §5 before launch.

4. How the platform enforces this

Control	Where
The payment methods PlayStake accepts are fixed in code (`card` only). Deposits send this list to Stripe, so a method switched on in the Stripe Dashboard — buy-now-pay-later, crypto, bank redirects — can never be offered to a customer without a code change and review.	`APPROVED_PAYMENT_METHOD_TYPES`, `src/lib/payments/policy.ts`; `createPaymentIntent`, `src/lib/payments/stripe.ts`
A second check when a deposit is confirmed: if a payment used anything other than an approved method, it is **not** credited, the transaction is marked failed, and staff are alerted to refund it.	`handlePaymentIntentSucceeded`, `src/app/api/webhooks/stripe/route.ts`
Money can only enter a customer balance from the `STRIPE_SOURCE` system account after a signature-verified Stripe webhook, and only leave to `STRIPE_SINK` through a Stripe payout. There is no staff tool, script or other route that credits or debits a balance from outside.	`src/lib/ledger/transfer.ts` and its callers
Live payments are refused unless explicitly enabled; today only a Stripe test key is accepted.	`assertTestPaymentsEnabled`, `src/lib/payments/policy.ts`
Automated tests check the approved list and that deposits pin it.	`tests/unit/payments/payment-methods.test.ts`

Moving stakes between customers' balances inside PlayStake (into escrow and out to the winner) is done on PlayStake's own ledger and involves no external payment.

5. Adding a payment method or provider

Nothing is added until every step is complete and recorded:

1. Confirm on the FCA register that the provider is a PSP under the PSRs for the service it will provide, and record the firm reference number and date checked.
2. Get the provider's written approval for licensed gambling.
3. Confirm the method is not a credit product (gambling on credit cards and similar credit is prohibited in Great Britain).
4. Assess AML and fraud risk (Policy 07) and how the payer's name will be matched to the verified customer.
5. Sign the contract and data processing agreement.
6. Add the method to `APPROVED_PAYMENT_METHOD_TYPES` through a Standard change (Document 11 §5), with tests.
7. Update this register and the outsourcing map (Document 08).
8. Consider whether it is a key event to notify (Document 14).

6. Ongoing checks

- **Annually**, and whenever we hear of a change, re-check each provider on the FCA register and record the result here.
- **Quarterly**, check the Stripe Dashboard's payment method settings match §2 (the code overrides them, but a mismatch shows someone tried to change them).
- If a provider loses its authorisation, stop taking payments through it at once and treat it as a Severity 2 incident (Document 14).

7. Open points

#	Point	Owner
1	Obtain Stripe's written approval for gambling, or appoint a gambling-approved PSP	Head of Compliance

#	Point	Owner
2	Confirm the Stripe entity and FRN on the FCA register	Head of Compliance
3	**Block credit cards.** The approved method is "card", which includes credit cards. Before launch, refuse credit-funded cards (for example a Stripe Radar rule blocking `card_funding = credit`, with a server-side check on the payment method's funding type)	Head of Compliance / engineering
4	~~Switch currency from USD to GBP for UK customers~~ **Done 20 October 2026.** Deposits, payouts, balances, records and everything customers see are in GBP	Engineering
5	Take legal advice confirming that moving stakes between customer balances on PlayStake's own ledger is not itself a regulated payment service	Head of Compliance

Version	Date	Change
0.1	30 September 2026	First draft

Document 17 — Data Protection Impact Assessment: Identity Verification (Didit)

Controller	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance; [DPO OR PRIVACY LEAD]
Version	0.1 — first draft for review
Review	Before switching Didit from sandbox to live; then annually, and on any change to the workflow, provider or data held
Relates to	UK GDPR Articles 6, 9, 28, 35 and 44–49; Data Protection Act 2018 Schedule 1; Gambling Commission LCCP social responsibility code 3.2 (age verification) and customer due diligence; Money Laundering Regulations 2017 (as they apply to PlayStake — to be confirmed); Documents 06, 07, 08, 13

> First draft prepared on 22 October 2026 from the integration as built. `[BRACKETS]` and the questions in section 8 must be answered, ideally with legal or data-protection advice, before Didit is used for real customers. A DPIA is required here because the processing uses biometric data to identify people and is carried out at scale on everyone who wants to gamble.

1. What the processing is

Before a customer can deposit, use free-to-play features or gamble, PlayStake must verify their identity, age and address, and screen them for financial-crime risk (Document 06, Document 07). PlayStake uses Didit's hosted verification:

1. The customer starts the check from **Verify ID**. PlayStake creates a Didit session, passing only the customer's PlayStake user id, email and the date of birth they declared at sign-up.
2. On Didit's page the customer photographs their identity document, takes a selfie, and uploads a proof of address.
3. Didit checks the document for authenticity and tampering, runs a passive liveness check, matches the selfie to the document photo, reads the date of birth and declines anyone under 18, checks the proof of address, and screens the customer against sanctions, PEP and adverse-media lists (with ongoing re-screening).
4. PlayStake receives a signed notification, re-reads the decision from Didit's API, and stores: name, date of birth, address, document type and issuing country, Didit's status, scores and reasons. **Images are not copied to PlayStake.**
5. PlayStake then runs its own checks (date of birth against sign-up, same identity on another account, GAMSTOP) and either verifies the customer, rejects with reasons, or sends the case to staff.

A manual upload route remains as a fallback; those documents are stored encrypted by PlayStake (Document 06 §3.2).

2. Data, people and volumes

Item	Detail
Data subjects	Adults (and anyone attempting to sign up, including under-18s who must be refused) who want to gamble on PlayStake, mainly UK residents
Personal data	Name, date of birth, address, email, document type, number and expiry (held by Didit), proof-of-address document, IP and device data collected by Didit
Special category data	Facial biometric data (selfie and face template) used to confirm the person matches the document — Article 9
Criminal-offence-type data	Possible: adverse-media and sanctions hits can relate to alleged offences — Article 10

Item	Detail
Volume	Beta: under 500 a month. At launch: [ESTIMATE]
Retention	Didit: [PERIOD SET IN DIDIT — align with the AML retention period, normally 5 years after the relationship ends]. PlayStake: verification record for the same period (Privacy Policy)

3. Lawful basis

Purpose	Article 6 basis	Article 9 / 10 condition
Age verification (keep under-18s out)	Legal obligation — Gambling Act 2005 and licence conditions	DPA 2018 Sch 1 Part 2: **preventing or detecting unlawful acts** (para 10) and **regulatory requirements** (para 12); [CONFIRM WITH ADVICE]
Identity and address verification, one-person-one-account	Legal obligation (licence conditions, customer due diligence)	As above
AML screening and ongoing monitoring	Legal obligation	Sch 1 para 10 / 12; Article 10 via Sch 1 Part 3 [CONFIRM]
Fraud prevention (document forgery, liveness attacks)	Legitimate interests and legal obligation	Sch 1 para 10 / 14 (preventing fraud) [CONFIRM]

PlayStake needs an **appropriate policy document** under DPA 2018 Sch 1 Part 4 for these conditions: [TO DRAFT — can be an annex to this document].

Consent is **not** relied on: verification is a condition of gambling and the customer has no real choice. The alternative for customers who can't or won't use biometrics is the manual upload route, which still involves a selfie checked by a person — [DECIDE whether to offer a non-biometric route, e.g. electoral-roll check plus document, and record the decision here].

4. Necessity and proportionality

- **Necessary:** the Gambling Commission requires age and identity to be verified before gambling; a document plus liveness and face match is the standard way to show the person is real and is the document holder, which also stops under-18s using a parent's ID.
- **Minimised:** PlayStake keeps only what it needs to show the check was done and to run its own controls; images stay with Didit. Didit is not asked for data PlayStake doesn't use (database lookups and proof-of-funds are off).
- **Accurate:** borderline results go to a person; the customer is told the reasons for a decline and can try again; staff can correct a record.
- **Transparent:** the Privacy Policy names Didit, explains the selfie is biometric, and lists what PlayStake receives; the Verify ID page says what is needed and links to the Privacy Policy.
- **Rights:** access, rectification and erasure requests are handled under the Privacy Policy; erasure is limited while the AML retention period runs.

5. Risks and controls

Risk to individuals	Likelihood / severity	Controls	Residual
Biometric or document data breached at the provider	Low / high	Didit ISO 27001 and SOC 2 Type II; DPA with security terms; images never copied to PlayStake; access to Didit's console limited to named staff with two-factor	Low
Breach at PlayStake	Low / medium	Only text results stored; database access controlled (Document 13); webhook signatures and timestamps verified; decisions re-read from Didit's API	Low

Risk to individuals	Likelihood / severity	Controls	Residual
Wrongly declined (e.g. poor photo, unusual document) and locked out of the service	Medium / medium	Reasons shown; retry allowed; borderline results reviewed by a person; manual upload fallback	Low
Under-18 approved	Low / high	Didit age rule (18+, decline) on every accepted country; PlayStake re-checks age from the document before any automatic approval; under-18 closure process (Document 06)	Low
Bias in face matching or liveness for some groups	Unknown / medium	iBeta liveness certification; borderline matches go to a person; [ASK DIDIT for accuracy figures by demographic]	To assess
Excessive retention	Medium / medium	Retention set in Didit to the AML period; deletion on expiry [CONFIRM Didit deletes automatically]	Low once set
International transfer outside the UK	Possible / medium	Didit is in the EU (adequacy regulations apply); [CONFIRM all sub-processors and locations; IDTA or addendum for any outside UK/EU adequacy]	To confirm
AML false positive treated as fact	Medium / medium	AML hits never auto-decline; staff review every possible match and record the outcome (Document 07)	Low

6. Measures agreed

1. Sign Didit's DPA (Article 28) and record it in the supplier register (Document 08).
2. Set Didit's retention to [PERIOD] and confirm automatic deletion.
3. Restrict Didit console access to named staff, with two-factor sign-in.
4. Keep the manual upload route, and decide on a non-biometric alternative (section 3).
5. Review a monthly sample of automatic approvals against Didit's evidence (Document 06 §8).
6. Re-assess this DPIA before going live and when the workflow changes.

7. Sign-off

Role	Name	Decision	Date
Head of Compliance	[NAME]	[APPROVE / CHANGES]	
DPO or privacy lead	[NAME]	[ADVICE]	
Board / MLRO	[NAME]		

If residual high risk remains that cannot be reduced, consult the ICO before processing (Article 36).

8. Questions to put to Didit

1. Where are document images, selfies and face templates processed and stored? List all sub-processors and countries.
2. Is any biometric template kept after the session, for example for duplicate detection across Didit customers?
3. What retention options are there, and is deletion automatic and evidenced?
4. Accuracy and bias: false-accept and false-reject rates for liveness and face match, by age, sex and skin tone.
5. Breach notification timescales and process.
6. UK certification (UK digital verification services trust framework), or independent accuracy testing for UK documents.

Version history

Version	Date	Change
0.1	22 October 2026	First draft from the Didit integration as built

Document 18 — Data Protection Impact Assessment: Match Recordings

Controller	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance; [DPO OR PRIVACY LEAD]
Version	0.1 — first draft for review
Review	Before recording is switched on for real customers; then annually, and on any change to what is recorded, who can watch, the storage provider or retention
Relates to	UK GDPR Articles 5, 6, 13, 28, 35 and 44–49; Gambling Commission LCCP (fair and open gambling, complaints and ADR); Documents 01, 02, 08, 13; Match Rules (recording rule)

> First draft prepared on 26 October 2026 from the recorder as built. `[BRACKETS]` and the questions in section 8 must be answered, ideally with legal or data-protection advice, before recording is switched on (`RECORDING_ENABLED`). A DPIA is required because the processing systematically records every customer's video and voice at every refereed match, and because the recordings may show third parties and the inside of people's homes.

1. What the processing is

Every refereed match is recorded by PlayStake so that a dispute or complaint can be decided on evidence that PlayStake holds, rather than on Kick's past broadcasts, which players can delete.

1. When the referee clicks **Start match**, PlayStake's recorder service opens a private recording page that shows both players' and the referee's Kick streams (through Kick's own embedded player), the match clock, the real time, match events and match chat.
2. The recorder captures that page and the sound of all three streams into one 1080p video, uploading it in 5-minute pieces while it records.
3. When the referee records the result (or the match is cancelled, or reaches the 2-hour limit) the recording stops. The pieces are joined into one file, its SHA-256 fingerprint is written into the match's hash-chained referee audit trail, and the file is stored privately in Cloudflare R2.
4. Only PlayStake admins and approved dispute reviewers who pass the conflict checks (Document 01) can watch a recording, and only from the dispute it belongs to. Each viewing uses a private link that expires after 15 minutes and is logged in the admin audit log.

Players and referees are told in the Match Rules, which they must accept (versioned) before playing or officiating, and in the Privacy Policy.

2. Data, people and volumes

Item	Detail
Data subjects	Players and referees in refereed matches; anyone who appears or is heard on their streams (family, housemates, Kick chat shown on screen)
Personal data	Video and sound of each stream (face, voice, surroundings, anything shown on screen), display names, Kick channel names, match chat, match events and times; viewing log of who watched
Special category data	Not intended. Video can incidentally reveal health, religion or other special category information; it is not used to infer or process it. Recordings are not used for facial recognition or any biometric identification
Volume	About 230 MB per 30-minute match. Beta: [ESTIMATE] matches a month

Item	Detail
Retention	30 days after the match. If disputed: held until the dispute is decided, then 12 months (8-week complaints process plus IBAS referral), longer only for an investigation or legal claim. Deleted automatically by the hourly retention job; the database row remains, marked deleted

3. Lawful basis

- **Legitimate interests (Article 6(1)(f))**: deciding disputes fairly, protecting players' money from cheating and fixing, and meeting the Gambling Commission's expectations on fair gambling, complaints and ADR. The balancing test: players already broadcast these streams publicly on Kick by choice; the recording adds no new viewers beyond a small number of reviewers; it is short-lived; it protects the players themselves. [CONFIRM with advisor whether contract (Article 6(1)(b)) is the better basis for players, since recording is part of the service they sign up to.]
- Customers cannot opt out of recording and still play a refereed match, because the dispute process depends on it. This is stated before they accept the Match Rules.

4. Necessity and proportionality

- **Why not rely on Kick's past broadcasts?** Players control their own Kick archives and can delete them, or not enable them; the evidence would be missing exactly when it matters most.
- **What is recorded is limited**: only from match start to result, only the three streams already public on Kick, only refereed matches.
- **Who can watch is limited**: independent reviewers and admins, never other players, never the original referee.
- **Retention is short** for the 95%+ of matches that are never disputed (30 days).

5. Risks and controls

Risk to individuals	Likelihood / severity	Controls	Residual
Recordings breached or leaked	Low / high	Private R2 bucket, never public; access keys held only by the web app and recorder; playback via 15-minute signed links; every viewing logged; Cloudflare security certifications (ISO 27001, SOC 2)	Low
Misuse by a reviewer (sharing, watching without reason)	Low / medium	Only from an assigned dispute, after the conflict checks; every viewing in the append-only admin audit log; reviewers bound by the Referee Code (confidentiality); periodic review of the viewing log	Low
Third parties (family, housemates) recorded without knowing	Medium / low	Match Rules tell players anything on stream may be recorded; they choose what their camera shows; retention short	Low
Recording tampered with to change an outcome	Low / high	SHA-256 sealed into the hash-chained referee audit trail at the moment of recording; reviewers see the fingerprint	Low
Kept too long	Low / medium	Automatic hourly deletion at the retention date; disputes hold recordings only while open, then 12 months	Low
Recording missing or broken when a dispute is filed	Medium / medium	Pieces uploaded every 5 minutes, so a failure loses little; failures recorded with a reason; reviewers fall back to the players' Kick channels	Medium (operational, not a privacy risk)
International transfer	Possible / medium	R2 bucket location set to EU (or UK) jurisdiction [CONFIRM]; Cloudflare DPA includes the UK addendum and SCCs	To confirm

6. Measures agreed

1. Accept Cloudflare's DPA (Article 28) and record Cloudflare R2 in the supplier register (Document 08).

2. Create the R2 bucket with **EU jurisdiction** and no public access; issue a bucket-scoped API token with object read/write only.
3. Keep the Match Rules recording rule and the Privacy Policy wording in step with what is recorded.
4. Review the recording viewing log monthly alongside dispute outcomes.
5. Answer subject access requests for recordings by giving the person the clip of their own match while it is held (mask other people where needed) [CONFIRM approach with advisor].
6. Re-assess this DPIA before switching recording on, and on any change to what is recorded.

7. Sign-off

Role	Name	Decision	Date
Head of Compliance	[NAME]	[APPROVE / CHANGES]	
DPO or privacy lead	[NAME]	[ADVICE]	
Board	[NAME]		

If residual high risk remains that cannot be reduced, consult the ICO before processing (Article 36).

8. Questions to settle

1. Contract or legitimate interests as the lawful basis for recording players (section 3).
2. Does recording Kick streams through Kick's embedded player sit within Kick's terms of service? Ask Kick, and record the answer.
3. R2 bucket jurisdiction (EU or UK) and Cloudflare sub-processors.
4. Handling of subject access requests that include other people (section 6.5).

Version history

Version	Date	Change
0.1	26 October 2026	First draft from the recorder as built

Policy 19 — Protection of Customer Funds

Operator	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance; [FINANCE LEAD]
Version	0.1 — draft for licence application
Review	Annually; before any change to how customer funds are held; whenever a new bank, payment provider or trust arrangement is introduced
Relates to	LCCP licence condition 4.1.1 (segregation of customer funds) and 4.2.1 (disclosure to customers); Gambling Commission guidance *Customer funds: segregation, disclosure to customers and reporting requirements*; Terms §08 "Protection of customer funds"; Policies 07, 16; Documents 09, 12

> Draft prepared on 27 October 2026 from the platform as built. `[BRACKETS]` must be completed, ideally with advice, before submission.

1. What PlayStake holds

PlayStake holds customer funds: money customers deposit by card, their winnings and refunds, and stakes held for matches in progress. Each customer's balance is a ledger account in PlayStake's double-entry ledger (Document 09 §4). Stakes move into a per-match escrow ledger account when both players consent and leave it at settlement or refund; escrow is an internal ledger record, not a separate bank account or a trust.

The money itself is held in PlayStake's account with its payment provider (Stripe, Policy 16) and in PlayStake's business bank account [BANK NAME], together with the company's own money.

2. Our rating

PlayStake's rating under LCCP 4.2.1 is **"not protected – no segregation"**.

Rating (LCCP 4.2.1)	Meaning	PlayStake
Not protected – no segregation	Customer funds are held with company funds	**Yes, today**
Not protected – segregation of customer funds	Customer funds are in separate accounts, but customers have no legal claim to them on insolvency	Possible next step (§6)
Medium protection	Separate accounts with legal arrangements that give customers priority, without independent audit	—
High protection	Trust or similar arrangement, independently audited, giving customers ownership of their funds on insolvency	—

3. What customers are told, and when

When	What happens	Where in the platform
Always	The Terms state the rating, what it means, and how funds are held (Terms §08 "Protection of customer funds", `/terms#funds-protection`)	`src/app/terms/page.tsx`

When	What happens	Where in the platform
Before the first deposit	The deposit page shows, in writing, the Commission's wording for the rating — "*We do not keep customer funds separate from company funds. This means that in the event of insolvency customer funds will not be protected.*" — and an explanation. The customer must tick to confirm they have read and understood it. Deposits are refused until they do.	`/wallet/deposit`; `POST /api/wallet/funds-protection`; deposit API refuses with `FUNDS_PROTECTION_REQUIRED`
Before gambling with deposited funds	Any customer who has deposited and has not acknowledged the current wording (for example, deposited before this was introduced, or after a change) can't stake until they acknowledge it.	`assertCanWager` → `assertFundsProtectionAcknowledgedIfDeposited`
Every deposit	The statement is repeated next to the deposit button.	`/wallet/deposit`
At least every six months	Because the rating is "not protected", the acknowledgement expires after six months. A reminder appears in the dashboard stating **the funds PlayStake holds for the customer** and the rating; the customer must acknowledge it before they can stake again. They can withdraw at any time.	`FundsProtectionReminder` in the dashboard; acknowledgement older than 182 days is treated as not given
After a change to the arrangement	Changing the rating or wording bumps `FUNDS_PROTECTION_VERSION`; every customer must acknowledge the new wording before their next deposit or stake.	`src/lib/compliance/funds-protection.ts`

Each acknowledgement is recorded on the customer's account with the version of the wording and the time.

4. Controls on the funds themselves

- **Ledger.** Every movement is a balanced double-entry transfer; balances can't go below zero; entries are append-only (database trigger). The ledger audit runs daily and checks every account and transaction (Document 13).
- **Reconciliation.** [FINANCE LEAD] reconciles the total of customer balances and escrow in the ledger against the money held with Stripe and [BANK NAME] **[DAILY / WEEKLY]**, and investigates any difference. Records are kept for 6 years. [CONFIRM frequency]
- **Withdrawals.** Customers can withdraw their balance at any time, including while on a break or self-excluded (Policies 03, 04), subject to identity and AML checks (Policy 07).
- **No lending or use of customer funds** for company expenses beyond the fee PlayStake earns at settlement. [CONFIRM with finance and advisor]

5. Reporting

- The Commission is told of PlayStake's rating in the application and in regulatory returns, and of any change to it.
- A change to how customer funds are held is assessed under the change process before it happens, the Terms and this policy are updated, the wording version is bumped, and customers re-acknowledge it.
- Any material financial difficulty that could affect customer funds is a key event (Document 14 §6).

6. Moving to a higher rating

To move to "not protected – segregation of customer funds" or higher, PlayStake would open a designated customer-funds bank account, sweep customer balances into it daily, and (for medium or high) put legal and audit arrangements in place, then update the Terms, this policy, `FUNDS_PROTECTION_LEVEL` and the wording version. [DECIDE with advisor whether to do this before launch]

Version history

Version	Date	Change
0.1	27 October 2026	First draft; disclosure, acknowledgement and six-monthly reminder built

Document 20 — UKGC Application: Technical Pack and Customer Funds (answers for the form)

Prepared for	[COMPLIANCE LEAD NAME] (Charles), completing the Gambling Commission operating licence application
Version	0.1 — 27 October 2026
Use	One answer per checklist item, ready to adapt into the form, with the document to attach. Facts were checked against the live platform on 27 October 2026.

> Two points on the checklist itself, checked against the Commission's website on 27 October 2026:
>
> 1. **ISO/IEC 27001 version.** The checklist says the RTS security requirements align to ISO/IEC 27001:**2013**. They now follow the **2022** standard: audits against the 2013 controls ended on 31 October 2024, and every security audit since 1 November 2024 must use the updated RTS controls aligned to 2022. Document 13 maps to 2022, which is correct.
> 2. **RTS page date.** The RTS page currently shows **last updated 31 October 2025** (RTS 12). The RTS 12 changes originally due on 30 June 2026 were postponed to **30 September 2026**; PlayStake meets them (Document 12 §3.1).
> 3. **"Separate client bank account" is ticked on the checklist, but PlayStake does not do this today.** Customer funds are held with company funds; the rating disclosed to customers is "not protected – no segregation" (Policy 19). Untick it, or open a designated account before submission and change the rating (Policy 19 §6).

A. Diagrams

Checklist item	Answer for the form	Attach
Operational model map — location, provider and operator of all systems and activities; key equipment	PlayStake builds and operates its own software. All remote gambling equipment — the web service, worker service, recorder service, PostgreSQL database and Redis — runs on Railway in its EU West region (`europe-west4`, Amsterdam, Netherlands), operated by PlayStake. No equipment is in Great Britain. Payments: Stripe. Identity checks: Didit (EU). Match recordings: Cloudflare R2 (EU). Email: Resend and Google Workspace. Monitoring: Sentry (EU, Germany). Every activity, from registration to regulatory reporting, is mapped with its provider and operator.	Document 10 (PDF)
System diagram / outsourcing map — payment services, age/identity, geolocation, marketing, customer service, fraud detection, hosting/storage	Diagram of all PlayStake systems and every external supplier, with a table per function: payment services (Stripe), age and identity (Didit; in-house upload as fallback), **geolocation (none today — a declared gap with an action)**, marketing (none; Google Analytics only on public pages with consent), customer service (in-house on Google Workspace), fraud detection (in-house anomaly, shared-identity and AML monitoring; Stripe Radar to configure), hosting and storage (Railway; Cloudflare R2 for recordings), ADR (IBAS, to sign), self-exclusion (GAMSTOP, to join).	Document 08 (PDF, includes the diagram)
End-to-end flow — registration → gambling → payout, with remote equipment locations	A ten-step flow from registration, email verification, Didit identity check, funds-protection disclosure and deposit-limit prompt, card deposit, finding a match, consent and escrow, refereed play with recording, dispute review, settlement and withdrawal, with the controls and the system and location at each step, the money-flow diagram, and an equipment-location table.	Document 09 (PDF)

B. Testing and independent assurance

Checklist item	Answer for the form	Attach
UK: testing strategy (third-party test house or in-house declaration)	PlayStake runs no games and no random number generation (withdrawn 25 October 2026); results of EA SPORTS FC 27 and Tekken 8 matches are decided by independent human referees. There is therefore no game, game rule set or RNG for a test house to certify. Platform functions (customer information, safer-gambling tools, interrupted matches, collusion controls, ledger integrity, eligibility, customer-funds disclosure, dispute review, recordings) are tested in-house: 384 automated tests run on every change in CI against real PostgreSQL and Redis, plus manual checks per release. We propose an **in-house declaration** for these functions and ask the Commission to confirm (Document 11 §3.3). Any future game or random element would be certified by an approved test house before release.	Document 11 (PDF)
UK: track RTS updates	Monthly check of the Commission's RTS pages, news and consultations, logged even when nothing changes; each change entered in a register with effective date, impact, action, owner and target date; delivered through change control. Last check 27 October 2026: RTS page last updated 31 October 2025; RTS 12 phase 2 effective 30 September 2026 and met; RTS 14 update (12 January 2026) under review.	Document 12 (PDF)
UAE: GCGRA technical standards (GLI series)	Planning draft: GCGRA standards are reported to build on GLI-19 (interactive gaming systems) and GLI-33 (event wagering systems); a gap analysis and certification plan are set out. To be confirmed directly with the GCGRA and UAE counsel.	Document 15 (PDF)
UAE: approved test labs	GLI and BMM (BMM North America, BMM Spain) are reported as approved; lab engagement is step 5 of the plan (months 6–9). To confirm with the GCGRA.	Document 15

C. Information security

Checklist item	Answer for the form	Attach
UK: RTS security requirements / ISO 27001 baseline	Information security policy mapped control by control to ISO/IEC 27001:2022 Annex A as used by the RTS security requirements, with status (in place / partial / planned), residual risks and a dated action list (penetration test, annual independent security audit within 6 months of grant, backups, key rotation, nonce-based CSP). Key safeguards: double-entry ledger with append-only entries and daily audit; staff two-factor sign-in; encrypted identity documents and tokens; card data handled only by Stripe; signed webhooks; append-only admin and referee audit trails; recordings sealed by SHA-256.	Document 13 (PDF)
UK: incident response and key-event reporting	Written procedure: reporting routes and automatic triggers (ledger-audit failure, worker heartbeat, Sentry, anomaly and AML alerts, supplier notices), triage by severity, response steps, customer and ICO notification, and key-event reporting to the Commission through eServices within five working days (LCCP 15.2.1), with playbooks and an incident register.	Document 14 (PDF)

D. Payments and protection of customer funds

Checklist item	Answer for the form	Attach
Customer funds segregation	PlayStake holds customer funds. They are **not** segregated: they are held in PlayStake's Stripe account and business bank account with company funds. Each customer's balance and each match's stakes are tracked in a double-entry ledger, audited daily and reconciled against the money held [FREQUENCY].	Policy 19

Checklist item	Answer for the form	Attach
Written disclosure of the insolvency protection level, acknowledged before gambling; extra reminders if "not protected"	Rating: **not protected – no segregation**. The Commission's wording is shown in writing before the first deposit; the customer must tick to acknowledge it, and deposits are refused until they do. Anyone who has deposited cannot stake until they have acknowledged the current wording. The statement is repeated on every deposit. Every six months a reminder states the funds held for the customer and must be acknowledged before they can stake again. Any change to the arrangement requires a fresh acknowledgement. Each acknowledgement is recorded with the wording version and time.	Policy 19 §3; screenshots in `evidence/`: `funds-1-before-first-deposit.png`, `funds-2-deposit-reminder.png`, `funds-3-six-monthly-reminder.png` (captured 27 October 2026)
Terms explain funds protection	Terms §08 "Protection of customer funds" (`playstake.org/terms#funds-protection`) states the rating with the Commission's wording, explains the four ratings, how PlayStake holds funds, the acknowledgement and six-monthly reminder, and links to the Commission's guidance.	Terms (PDF or link)
Payments only through PSR payment service providers	PlayStake does not provide payment services. Deposits (card, including Apple Pay and Google Pay) and withdrawals (payout to the customer's own bank account) go only through Stripe Payments UK Ltd, an FCA-authorised electronic money institution [FRN 900461 — confirm on the FCA register]. No cash, crypto, vouchers, third-party payments or direct transfers. Stripe is in test mode; live processing needs Stripe's written approval for gambling first.	Policy 16 (PDF)

E. Still to complete before submission

1. Company name, addresses, named people and the remaining `[BRACKETS]` across the documents.
2. Railway database backup location and a tested restore (Document 13 §6 item 1).
3. Resend sending region (Resend dashboard → Domains).
4. Reconciliation frequency and bank name (Policy 19 §4).
5. Untick "separate client bank account", or open one and move to "not protected – segregation" (Policy 19 §6).
6. Geolocation: decide on an IP-location check (Document 08 §6).
7. Sign the DPIAs (Documents 17, 18), IBAS agreement and GAMSTOP membership.